

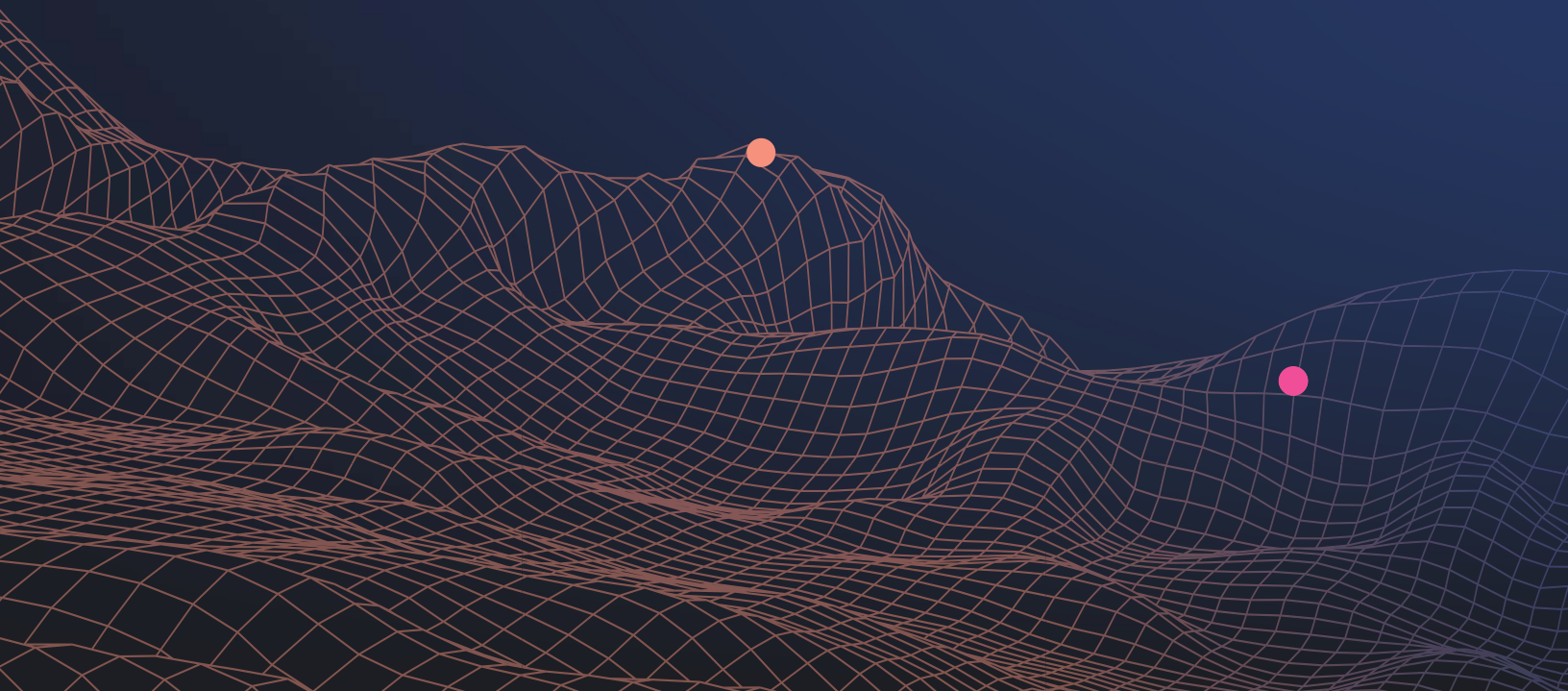


全球威胁报告

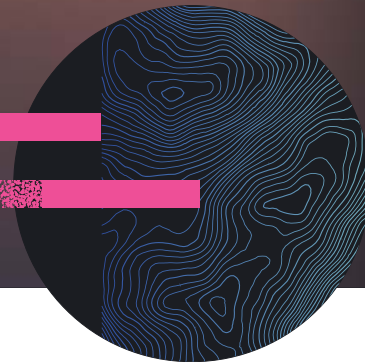
2022 年第 1 卷

目录

简介	3
报告摘要	4
趋势与关联性	5
恶意软件签名趋势	5
终端行为趋势	13
云安全趋势	22
威胁配置文件	28
BLISTER [REF7890]	29
PHOREAL [REF4322]	31
CUBA [REF9019]	33
QBOT [REF3726]	35
预测与建议	37
结论	40



简介



“未来的安全防护是开放式的。在现如今的环境中，威胁行为体活跃多变、发展迅速且手段充足，实现数字安全的最大希望则在于搭建尽可能兼具开放性和互操作性的平台，并围绕这些平台汇聚使命相同的防御卫士。”

– Nate Fick

美国网络空间和数字政策局巡回大使、前 Elastic 安全总经理、前 Endgame 首席执行官

本 Elastic 全球威胁报告是 [Elastic Security Labs](#) 的成果，该威胁研究部门擅长调查计算机网络入侵，分析恶意软件，针对各种威胁制定缓解措施，以及对情报进行分析。Elastic Security Labs 由一群充满激情的安全专家组成，他们通过研究各种安全主题来改善 Elastic 安全这款产品，同时还会与社区的其他成员分享研究成果。

我们的理念很简单：保护全球数据的最佳方式就是将防御技术作为自己的武器。我们之所以要打造对威胁能够形成强力反制的环境，是因为这是改变威胁形势的最有效也是唯一的一种方法。许多安全供应商采用的防御策略都是被动加观望，而威胁会不断适应和演变，因而需要采用更加积极主动的防御方式。

本报告介绍了威胁现象及趋势并提供了一些建议，我们相信这些建议将有助于各组织为未来做好准备。Elastic 在社区中公布的恶意软件研究、攻击模式和各类恶意活动，也一并归纳总结在了这份首次发布的报告中。

通过这份报告，我们发现受经济利益驱动威胁最为活跃，而且发起这些威胁的团体在加速采取行动。由于这些威胁扩展迅速，因此它们会对那些难以在自身环境中缓解威胁的组织造成影响，从而导致攻击者多次获得更大的利益。

Elastic 的遥测数据为本报告提供了数据经过验证的材料，这些数据均为自愿分享，并借助一流创新技术以及公共和其他第三方数据进行了扩充。本着保护客户身份的负责态度，本报告已去除了相应的身份信息。

Elastic 主要会将遥测数据用于提升功能的效用，以及通过本报告之类的刊物，为组织提供额外的安全背景信息。我们非常期待有机会以这样的方式与客户合作，分析他们的数据，并在对数据进行匿名化处理后，将我们的研究成果推广到整个安防行业。

为了有效预防网络安全威胁，组织需要同时具备可见性、能力和专业知识。Elastic 安全为这一需求提供了坚实的基础，借助我们的全球检测工具，可让您快速部署社区保护措施，抵御威胁。本报告包含有关我们看到的威胁和应对威胁的信息，这些信息对于开发未来的 Elastic 功能至关重要。

Elastic Security Labs 希望能够通过分享这些见解，规范关于供应商可见性的讨论，并展示我们独到的想法如何为安全技术的开发人员赋能，以便为他们的用户和整个社区尽可能带来积极成果。

报告摘要

对许多人来说,当前的安全状况实在令人失望,漏洞、漏洞利用、入侵和盗窃事件层出不穷。Elastic 对这一现状深感痛心,这在一定程度上也促使我们决定针对许多代价高昂且极具破坏性的症状研究治本方法,而不仅仅是推出新的治标方案赚钱。

随着检测和预防技术的有效性大幅提升,信息共享量已经达到历史最高水平。即便是普通大众也知晓不断扩大的全球威胁形势的影响,以及网络安全管理员面临的隐性挑战。

各种威胁不只具备新的能力,而且还都采用了新的手段,同时加快了活动的节奏。虽然组织跟踪的平均检测时间 (MTTD) 和平均补救时间 (MTTR) 指标在逐渐缩短,但威胁也在以更快的速度进行应对,从而使这些努力失效。

攻击者对于以情报为主导来跟踪、揭露和阻止他们行动的各种防御模式,也同样心里有数。许多金融威胁已经制定了伙伴联盟计划,并建立起了其他代理关系,确保在自身继续牟利的同时洗脱政府的制裁。对于攻击者而言,政府制裁是能让他们有所顾忌的为数不多的因素之一。遗憾的是,这些因素很少能够为受害者的生活和工作直接发挥防御作用。

我们决定针对许多代价高昂且极具破坏性的症状研究治本方法,而不仅仅是推出新的治标方案赚钱。

Elastic Security Labs 指出,尽管采用了技术、程序和人为缓解措施,但还是有相当大的一部分威胁能够取得一定程度的成功。我们注意到,这些威胁只要具备自己成熟的软件研发能力,就可以绕过复杂的终端检测和响应 (EDR)、防病毒软件、网络入侵检测系统 (NIDS) 和目录服务策略控制。服务提供商、软件供应链和内置操作系统框架 (如 Berkeley Packet Filter (BPF)) 遭到入侵不再是令人难以置信的事件,它们如今也成为了攻击面。

Elastic 客户和用户会希望了解本报告中的内容,以及我们全面掌握全球威胁形势对他们有怎样的影响。

我们的团队由事件响应人员、恶意软件和情报分析师、安全工程师、研究人员、数据科学家以及其他拥有数十年集体经验的专家组成,我们非常高兴在社区中分享我们的研究成果。

趋势与关联性

以下趋势代表了威胁所使用的主要工具、战术和程序,并已在 Elastic 遥测数据中识别出来。由于每个供应商都有自己的一套实现可见性的方法,因此像本报告这样的报告可为供应商该如何监测和缓解威胁提供宝贵见解。Elastic 遥测数据集成了来自 Elastic Endgame、Elastic Endpoint 和 Elastic 安全解决方案的数据,并通过这些技术部署缓解措施。

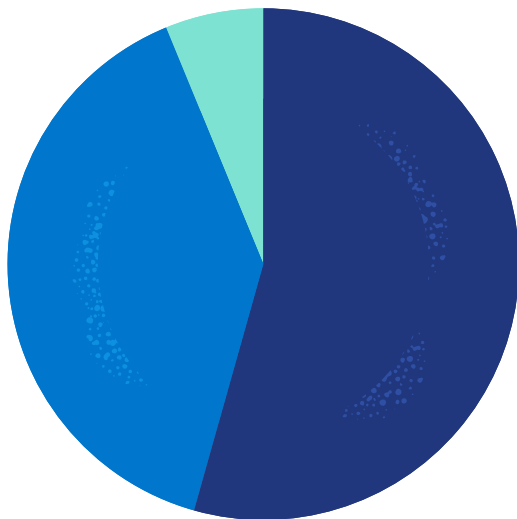
下面我们将概要介绍趋势和关联性,其中会分三个小节来介绍恶意软件签名、终端行为和云安全功能的趋势。为方便读者阅读,这些部分已根据适用情况做了进一步的调整。

恶意软件签名趋势

YARA 签名为 Elastic 安全解决方案提供了一层防御,能够根据字符串或字节序列识别与恶意软件相关的威胁活动。Elastic Endpoint Security 针对所有常见的终端操作系统推出了文件和内存级别的签名功能。作为我们免费开放承诺的一部分,Elastic 通过[保护工件](#)存储库向社区开放签名功能。

一开始,Elastic Security Labs 根据我们的遥测数据分析了特定操作系统 (OS) 中恶意软件的趋势。由此,我们发现约 54% 的恶意软件感染发生在 Windows 终端,而在 Linux 终端这一比例为 39% 左右。

约 54% 的恶意软件感染发生在 Windows 终端,
而在 Linux 终端这一比例为 39% 左右



按终端操作系统划分的 恶意软件

Windows.....	54.4%
Linux.....	39.4%
MacOS.....	6.2%

图 1:按终端操作系统划分的恶意软件

¹ Elastic 安全解决方案遥测数据由多种传感器和数据源生成,其中包括非 Elastic 开发的传感器。这些传感器和数据源数量太多,因此详情恕不赘述。

由于企业仍旧采用混合云的方法,并将更多基于 Linux 的终端用作后端基础架构,这就让攻击者有了可趁之机,将这个架构的二进制文件作为入侵武器,并通过定制交付技术予以分发。

再深入一点,我们发现,在基于 Linux 的恶意软件/有效负载方面,最大的贡献者是 Meterpreter (~14%),其次是 Gafgyt (~12%) 和 Mirai (~10%)。虽然这不足为奇,但我们可以很自信地说,攻击者仍在使用诸如 CobaltStrike 和 Metasploit 之类的框架来部署有效负载,确定漏洞利用目标以及设置后门来进一步执行命令。

如果 Shell 是在托管于云服务提供商 (CSP) 的 Linux 终端上创建的,就会看到这会十分有用,因为其中已安装了默认的 CSP CLI,并且可以调用预构建的脚本或模块来轻松发现和枚举。

尽管我们并未详细探讨 BPFDoor,但 Elastic Security Labs 也对这个 Linux 植入程序以及利用这个程序的通信客户端二进制文件[进行了](#)大量研究。

10 大 Linux 恶意软件/有效负载

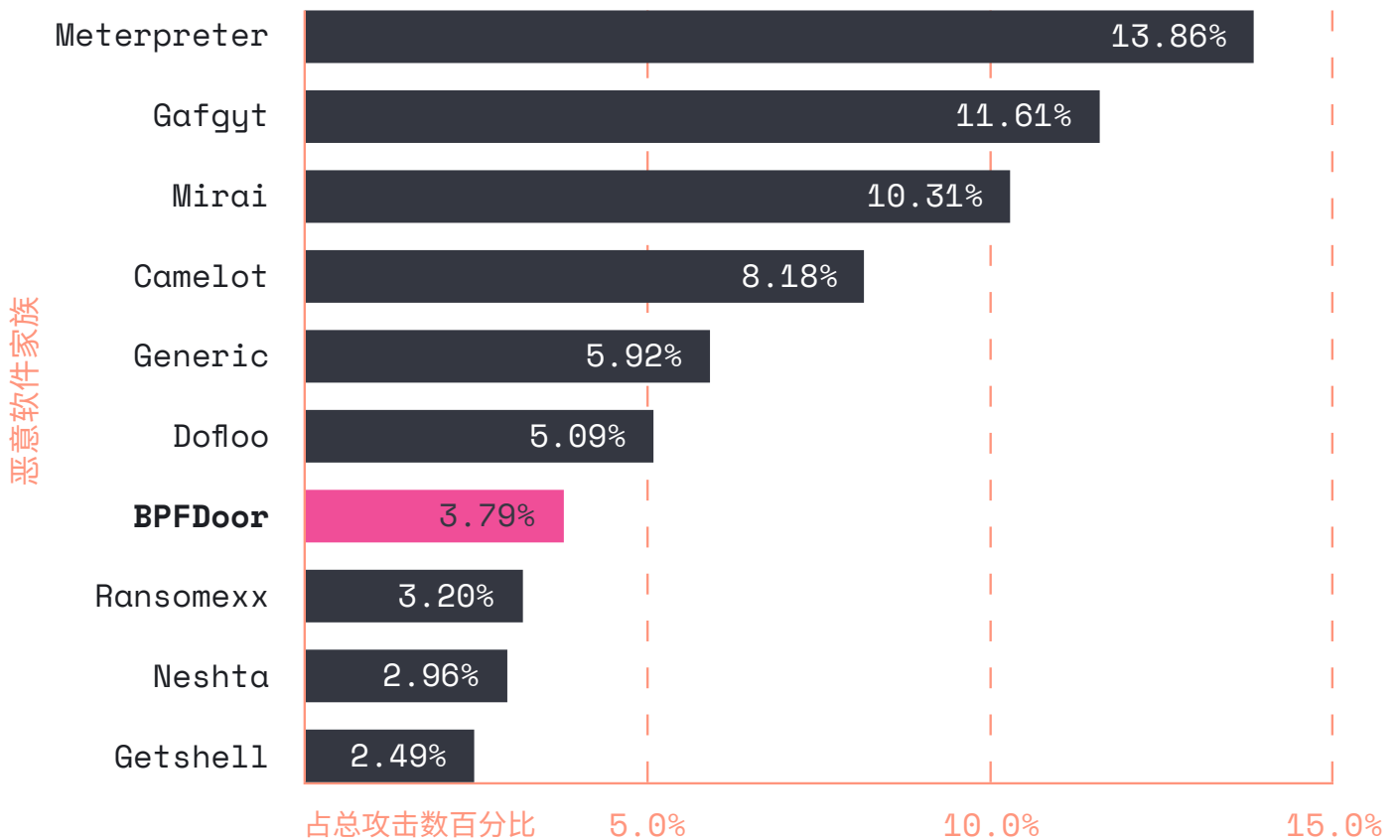


图 2:10 大 Linux 恶意软件和有效负载 (其中显示 BPFDoor 活动有所增加)

按类别划分的恶意软件

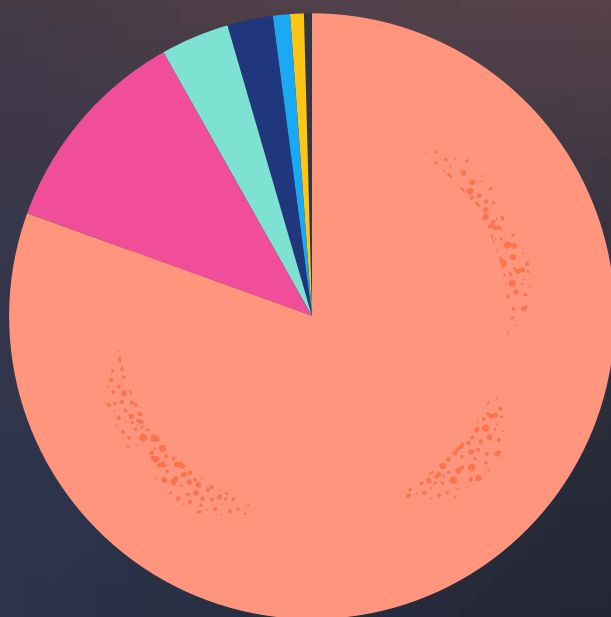
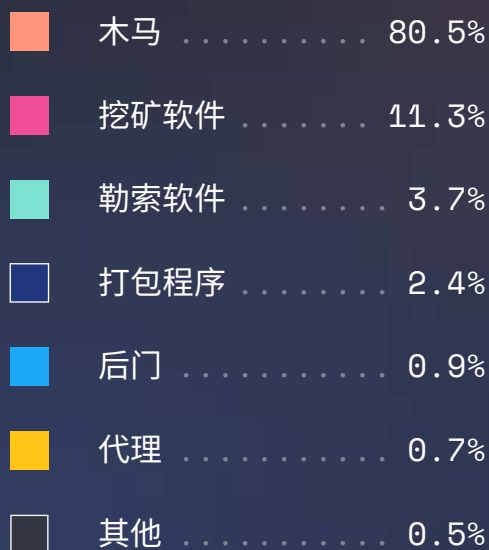


图 3:按类别划分的恶意软件

此外, Elastic Security Labs 还研究了全球各地出现的恶意软件类别, 结果发现约有 81% 的恶意软件是基于木马的, 其次是挖矿软件, 为 11% 左右。木马仍然是一种将可交付二进制文件作为入侵武器的首选方式, 这些二进制文件部署了 stager 和 dropper, 可用于执行入侵, 但也可以通过其他技术实现多种用途。我们的团队经常看到木马在送达目标前会先打包好, 这么做的目的是为了避开基于签名的检测引擎实施的潜在缓解措施。

挖矿软件虽然本质上并不是恶意的, 但最初往往是作为一种手段部署的, 通过利用受害者的计算资源来挖掘想要的加密货币 (出于匿名的需要, 通常是 Monero)。利欲熏心的攻击者通常会连同其他恶意软件家族一起部署这类挖矿软件, 以作为当所有其他方法不奏效时的应急方案。

XMRig 和 KWorker 是十分常见的工具, 但为获取公共源代码, 经常遭到挖矿软件滥用。Elastic Security Labs 最近发现了另一款流行的挖矿软件: LoudMiner。如下图所示, 在 2021 年 11 月之前, LoudMiner 检测量很少, 随后在 2022 年 2 月激增, 此后检测量保持稳定。LoudMiner 基于流行的 XMRig 开源代码构建而成, 旨在挖掘 Monero 加密货币, 为满足匿名需要还添加了其他功能。虽然检测是专门在 Linux 终端上进行的, 但 LoudMiner 支持跨平台运作, 并利用 CPU 在 Monero 区块链上处理分类账交易。

Elastic 安全最近在我们的“保护工件”存储库中开放了定制 YARA 和终端行为规则的源代码, 从中可以找到 [Linux.Cryptominer.LoudMiner](#) 逻辑。

按分发划分的挖矿软件家族

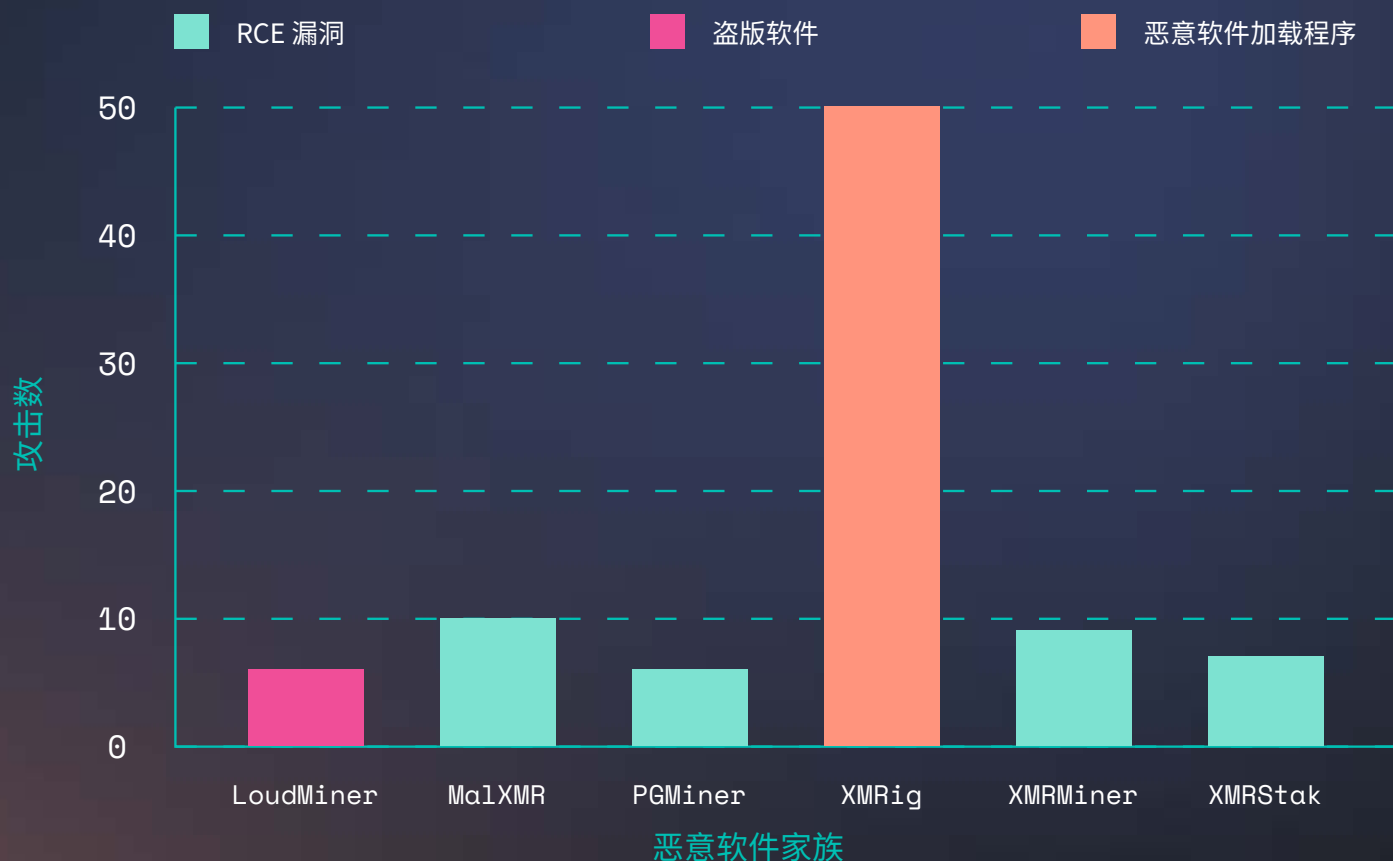


图 4: 按分发划分的挖矿软件家族

在继续查看恶意软件各类别的趋势时, 我们注意到一些不太常见的类型 (如后门和代理有效负载) 有所增加, 如下图所示。在 2022 年 3 月至 5 月间, Elastic Security Labs 注意到, 与下面列出的定制 YARA 签名相对应的各种客户的后门相关检测量有所增加。

- [Linux.Backdoor.Bash](#)
- [Linux.Backdoor.Generic](#)
- [Linux.Backdoor.TinysHELL](#)
- [MacOS.Backdoor.Applejesus](#)

通过 Linux 后门, 攻击者可以持续攻击和访问遭到入侵的终端。在基于云的环境中, 初始访问可能更容易通过部署了后门的面向公众的应用程序的漏洞实现, 然后再执行云环境发现和枚举。如果是在相同或相邻的 VPC 网络设置中, 将更容易访问 Windows 终端。

一段时间内的恶意软件流行程度

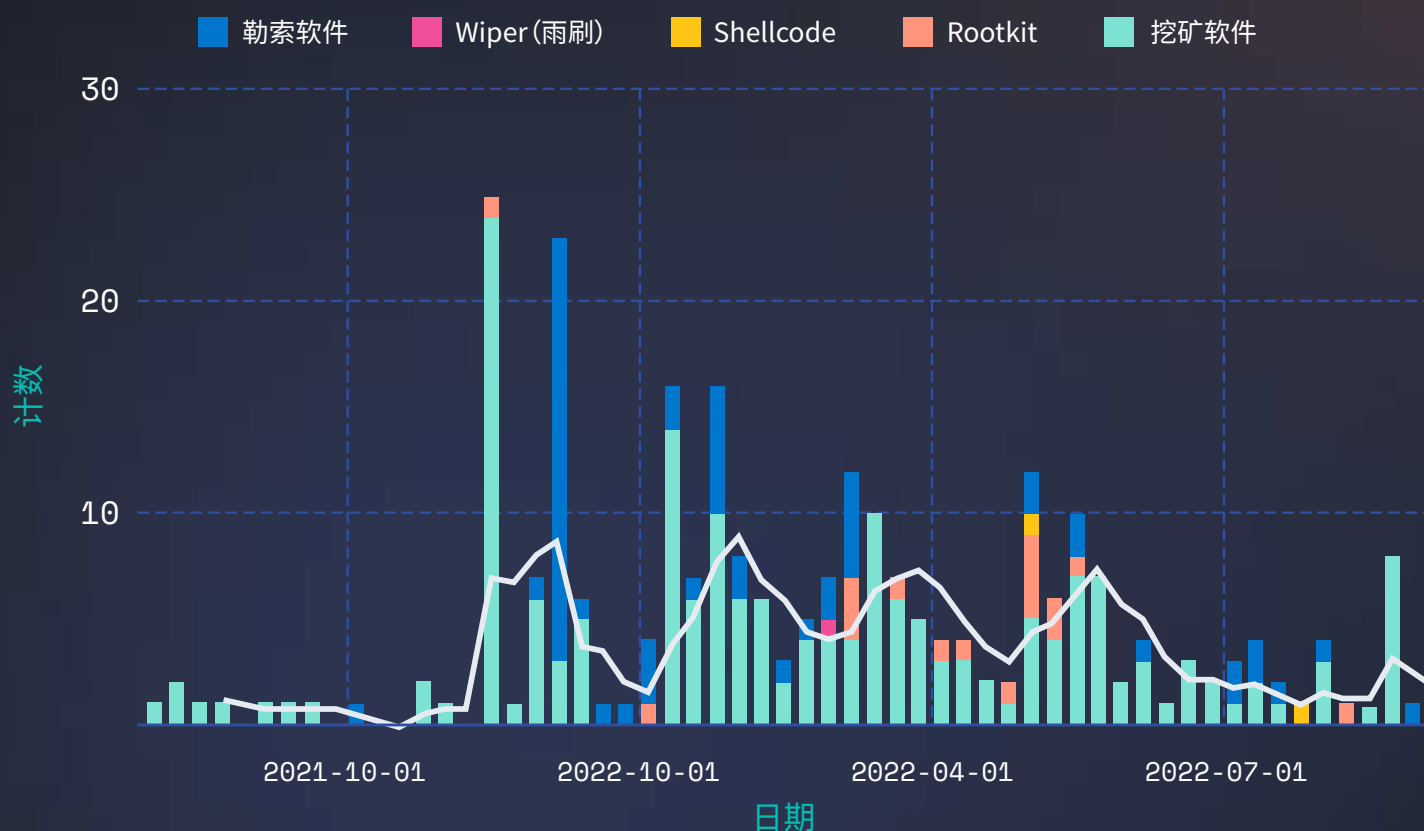


图 5:一段时间内的恶意软件流行程度

根据图 5 中的信息, Elastic 安全依靠我们的 [Linux.Proxy.Frp](#) 逻辑注意到, 能够利用代理执行潜在命令和控制的 Linux 二进制文件数量略有增加。在以 Linux 终端为攻击目标的情况下, 如前所述, 攻击者的策略通常包括使用后门二进制文件, 然后安装一个代理服务器来执行命令和控制。随着混合云环境更多地使用 Linux 后端服务器, 加上配置错误或可公开访问的安全防护实施不完善, 这种情况可能会更加频繁地出现。

正如图 3 所展示的,在 Elastic 检测到的恶意软件结果中,木马大约占了 80%,其中绝大部分与 Windows 有关。为了更深入地了解情况,我们决定分析图 6 中所示的木马家族在 Windows 终端中的普遍程度。

Windows 终端中木马的流行程度

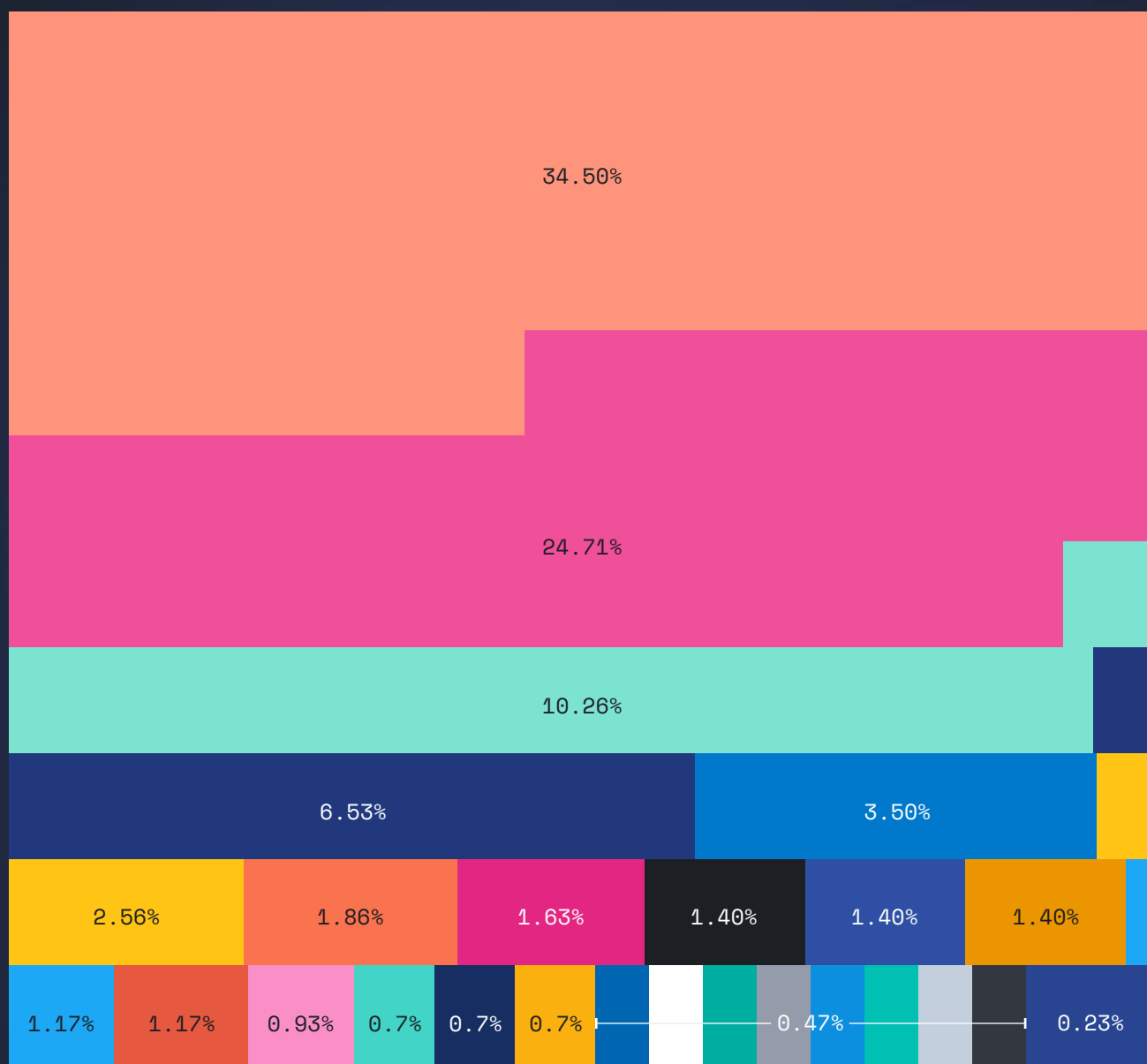


图 6: Windows 终端中木马的流行程度

除了恶意工具和大规模植入程序, COBALTSTRIKE 和 METASPLOIT 等商业现成 (COTS) 恶意软件家族在内存检测中占据了很大的比重。毫无疑问, CobaltStrike 是 Windows 终端最常见的恶意二进制文件或有效负载, 约占全部检测结果的 35%, 其次是 AgentTesla 和 RedLineStealer, 比重分别约为 25% 和 10%。Elastic Security Labs 之前就已经深入分析过 CobaltStrike, 并[探讨了](#)这一工具的使用和有效负载。为了继续促进开放和透明, 我们还[发布](#)了一个 CobaltStrike 信标提取器供使用。不出所料, COBALT STRIKE、METASPLOIT 和 MIMIKATZ 等攻击性工具继续霸占榜首, 表明这些工具的使用没有减缓。

AgentTesla 作为键盘记录器非常受欢迎, 并且攻击者也在不断加入其他功能作为入侵武器, 但 Elastic Security Labs 还是想要另外重点介绍 SnakeKeylogger。这两个键盘记录器都是通过电子邮件作为恶意附件主动分发的。如本报告前面所述, 通过 Microsoft Office 文档进行初始访问这种做法通常会被用于分发这些恶意软件, 然后从签名和受信任的二进制文件中执行代理。目标凭据通常与电子邮件和 FTP 客户端、Web 浏览器等相关。在采用混合云解决方案的环境中, 可能会允许使用有效帐户横向移动到云环境中, 而攻击者可能会在其中伺机访问关键或敏感资源和数据。

AgentTesla 和 SnakeKeylogger 签名:

- [Windows.Trojan.SnakeKeylogger](#)
- [Windows.Trojan.AgentTesla](#)

另一个值得关注且逐渐形成趋势的恶意软件家族是 RedLine Stealer, 它与键盘记录器有关, 并以 [Windows.Trojan.RedlineStealer](#) 被 Elastic Security Labs 检测出来。这个信息窃取软件通常也通过恶意垃圾邮件攻击活动分发, 并在新冠疫情期间迅速传播开来, 原因是邮件标题和主题均与疫情这一热议话题有关, 内容通常是鼓励用户下载并执行附件。采用和开发 RedLine Stealer 的人仍然大有人在, 这让财迷心窍的攻击者开始将攻击目标瞄准火热的加密货币钱包(如有), 用于替换我们在上文中探讨过的热门挖矿软件。随着智能合约和区块链技术逐渐流行起来, 并且事实证明, 通过不可更改的分类账来记录和跟踪分发非常有用, Elastic Security Labs 预测, 这项能力将会被普遍作为入侵武器, 继而诞生出更多信息窃取软件。

一段时间内 Windows 终端中的木马流行程度

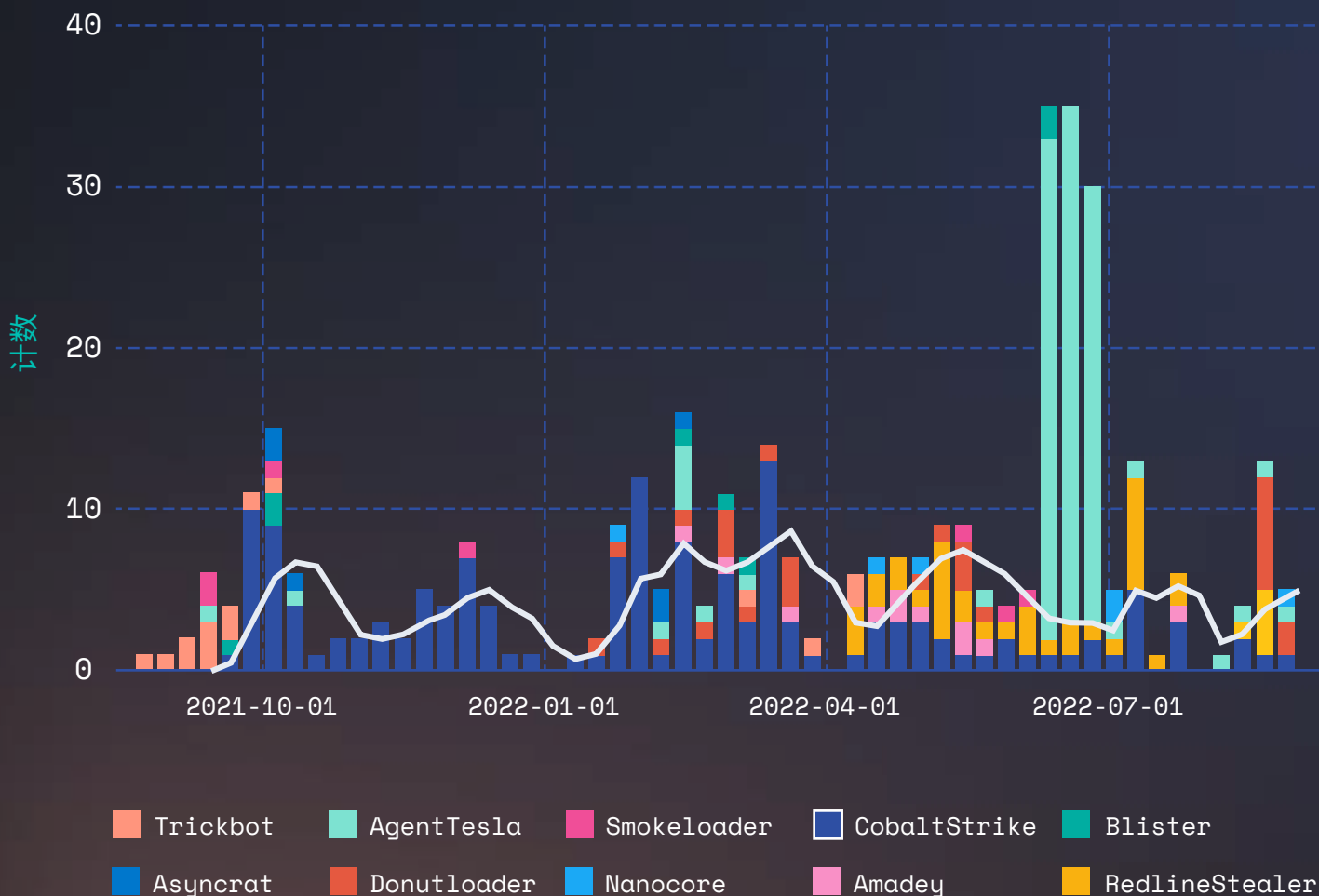


图 7：一段时间内 Windows 终端中木马的流行程度（不包括 AgentTesla、Redline Stealer 和 CobaltStrike）

虽然并不像在近期的公开研究中那么普遍，但 Elastic Security Labs 还是检测到了滥用开源加载程序框架 [Donut](#) 的行为。BitDefender 经研究发现，从 Orcus RAT 二进制文件注入的 Shellcode 在 Log4j2 零日漏洞期间作为来自 Donut 的加载程序被检测出来，Elastic 在单独一期[刊物](#)中对此进行了介绍。Elastic 安全发现 DonutLoader 非常值得关注，因为它拥有多种功能，能够加载恶意有效负载，以及在内存中执行 VBScript、JScript、EXE、DLL 文件以及 dotNET 程序集。如图 7 所示，DonutLoader 随着时间的推移依然热度不减，而检测出使用像 Trickbot 和 Emotet 这样的热门商品化恶意软件家族却没那么频繁。

对于 macOS 文件签名，MacKeeper 在所有检测结果中排名最高，约为 48%，XCSSet 排在第二，不到 17%。MacKeeper 是适用于 macOS 终端的实用软件套件，旨在帮助优化资源和监测内部资源。这个软件最初的用途是为 macOS 用户提供帮助，但经常遭到攻击者滥用，因为它拥有广泛的权限以及对流程和文件的访问权限。

MacOS 签名家族

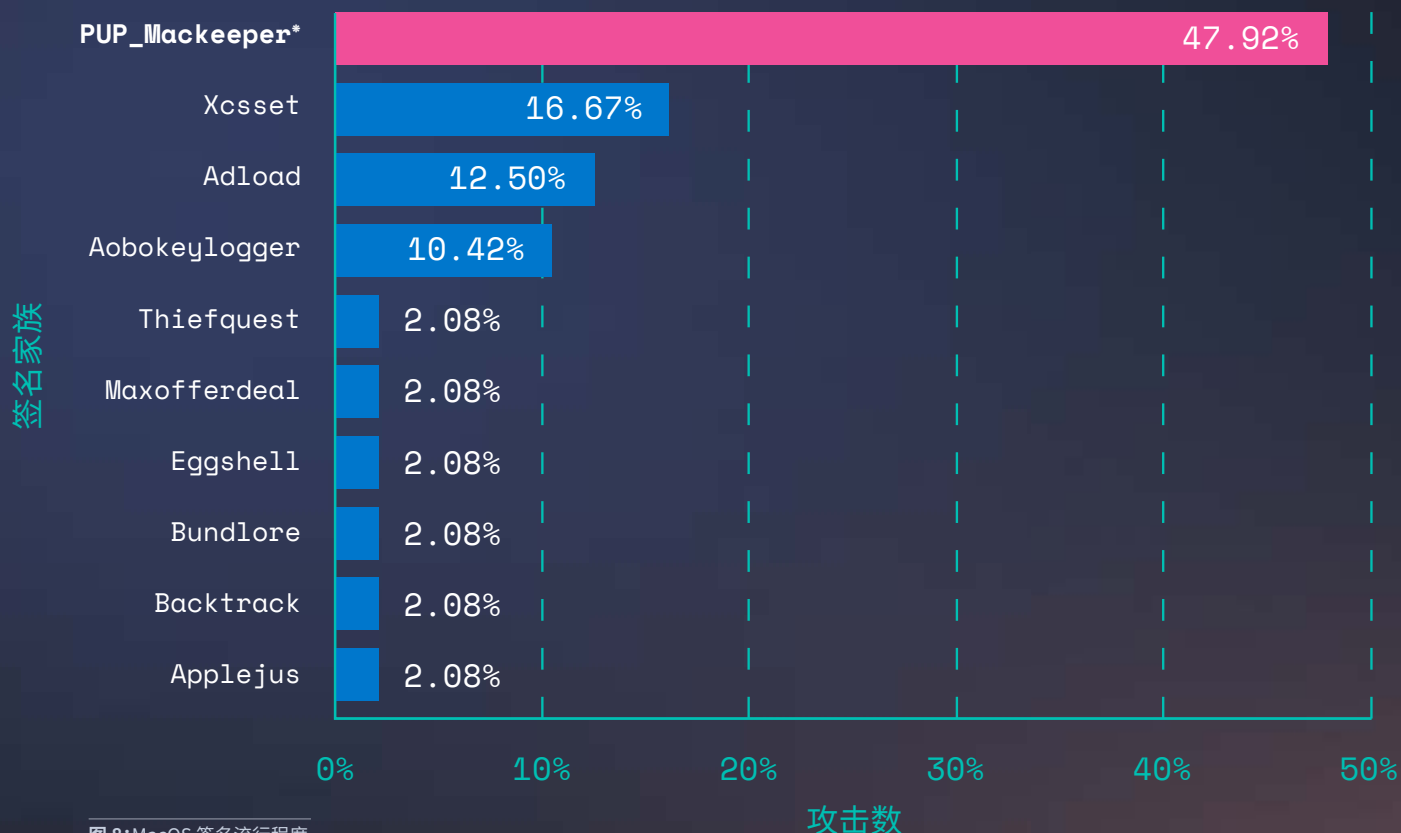


图 8: MacOS 签名流行程度

*我们未将 MacKeeper 列为恶意软件,但它可能会被滥用

挖矿软件的安装和使用往往都是以 Linux 和 Windows 终端为攻击目标的,但 Elastic Security Labs 在 macOS 终端也发现了这类软件的踪影,并且 mshelper 和 CreativeUpdater 等变体软件越来越常见。应该注意的是,macOS 挖矿软件的分发和受害者研究可能会越来越常见,并且开发者会利用 MacOS 和 JavaScript 来完成与攻击行动相关的任务。Node 包管理器 (NPM) 是 JavaScript 一个常用的包管理器,挖矿软件因而能够以恶意包的形式分发到进行开发工作的 macOS 终端,进而推高普及率。

终端行为趋势

开放、透明和协作是 Elastic 安全的核心所在。我们始终坚守这些原则,并在最近一期有关[保护工件](#)的刊物中分享了使用 Elastic 自主开发的终端行为逻辑,可用于识别攻击者的谍报技术。为撰写本报告,我们基于这一检测逻辑收集了全球各地有关告警和内置防御功能的遥测数据。

从将 MITRE ATT&CK® 映射到我们的终端行为规则开始,Elastic Security Labs 发现,告警中约有 34% 属于防御规避范围,其次是执行和凭据访问,分别各占约 22% 和 10%,具体如下图所示。

这表明防御规避不仅在目标攻击中,而且在所有攻击中都发挥了作用。除了绕过安全检测工具之外,这一类所用的技术还会绕过可见性,导致威胁驻留的时间更长,成功率更高。这也表明,对于假定存在安全检测工具的威胁来说,防御规避已经成为必要。

终端信号 (按战术划分)

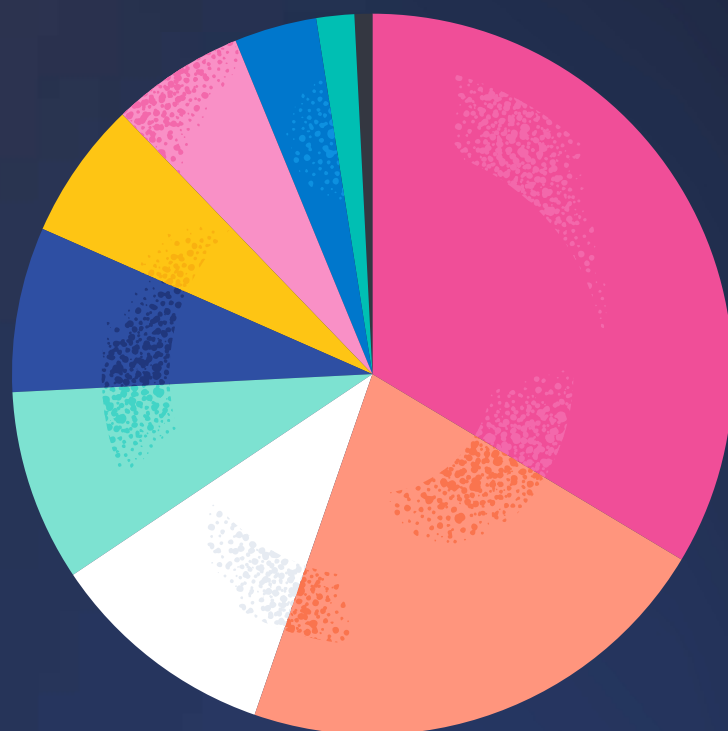
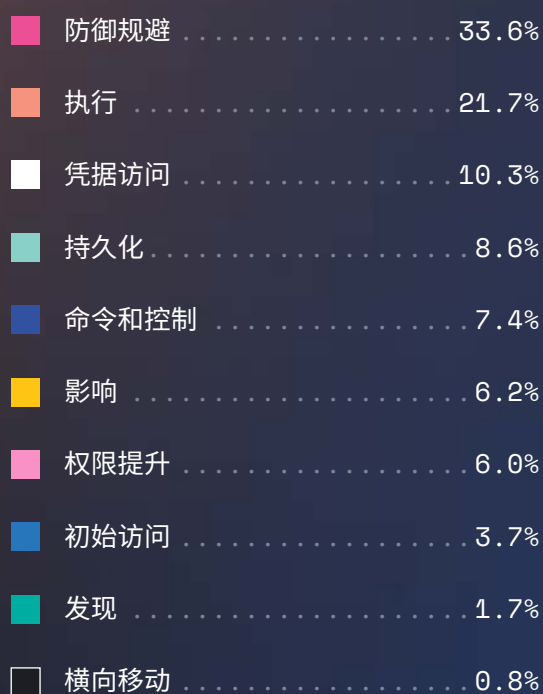


图 9: MITRE ATT&CK 针对终端行为规则的战术

防御规避

实现防御规避最重要的技术是伪装和系统二进制代理执行,在所有防御规避技术中,这两者占比为 72%。系统二进制代理执行用于将软件描述成经过合法签名的内置实用程序,以便被威胁合用来运行恶意软件。目前已知的子技术中的许多流程已经不是秘密,但仍有部分安全技术难以识别子技术运行的软件。

伪装成其他合法进程是另一种用于防御规避的常用技术,以便规避安全技术检查正在运行的软件、脚本或代码。

通过深入研究细节,Elastic 发现 Rundll32 在针对 Windows 系统的不同攻击阶段中依然被严重滥用。攻击者偏好使用这种子技术,因为它是离地攻击 (LotL) 技术的组成部分,借助这种技术,攻击者创建的恶意 DLL 可以从受信任和签名的 Windows 二进制文件中执行。在攻击生命周期的多个阶段,这个实用程序都会遭到严重滥用。

此外,Regsvr32 是另一个经常被滥用的 Windows 本地二进制文件,在防御规避告警中占有很大的比例。通常情况下,Regsvr32 会在恶意的 Microsoft 365 文档 (maldocs) 中被滥用,目的是执行恶意 DLL 或注册恶意文件。

技术

信号百分比

伪装	44.29%
系统二进制代理执行	30.00%
访问令牌操控	12.32%
进程注入	7.62%
BITS Jobs	4.74%
可信开发者实用程序代理执行	0.90%
XSL 脚本处理	0.66%
削弱防御	0.65%
防御规避利用	0.64%
系统脚本代理执行	0.13%
修改注册表	0.03%
移除主机指示器	0.01%

表 1:防御规避技术

监测优先级高的应用程序有 mshtml、msiexec、svchost、wefault、wemgr 和 runtimebroker。在重命名或从非标准目录执行 Windows 标准实用程序（常用方法）时，组织还应应对这类程序进行仔细检查。攻击者直接或间接篡改 Windows Defender 的情况也不少见。

初始访问和执行

初始访问和执行在入侵期间通常是相继发生的，并且入侵的各个阶段之间有着清晰的关系。

在分析初始访问技术的过程中，Elastic 安全发现有相当多的告警来自 Windows 终端，而这些终端所处的环境已经部署 Microsoft Office，且收到的电子邮件带有恶意链接或附件。将几种诱饵（例如，文档附件、ISO 对象、LNK 文件、脚本对象）作为武器使用仍然是进行初始访问的最常见方法。这些技术以接收方为目标，很多时候需要组合使用才能成功。

读者应该注意到，Microsoft 决定在 2022 年 7 月 27 日之前停用宏支持，这使得 LNK 和 ISO 对象在将有效负载作为入侵武器方面比文档诱饵更可靠。我们预测这是有可能的，像 ICEDID 之类广泛分布的恶意软件家族已经在采用这种方法。

下表列出了最常见的初始访问和执行技术。

规则名称	信号百分比
可疑的 Microsoft Office 子进程	34.00%
通过 Microsoft Office 引发 PowerShell 混淆	16.33%
RunDLL32/Regsvr32 负载丢弃可执行文件	13.47%
通过挂载的映像文件进行可疑执行	5.24%
从下载的 ISO 文件执行	5.00%
Microsoft 公式编辑器子进程	3.66%
经由 Microsoft Office 的 WMI 镜像负载	2.93%
通过 Microsoft Office 插件进行可疑执行	2.56%
通过 MSIEXEC 执行潜在的远程文件	2.44%
通过 Microsoft Office 应用程序进行初始访问或执行	2.44%

表 2: 排名前 10 位的触发的 Elastic 初始访问规则

执行技术

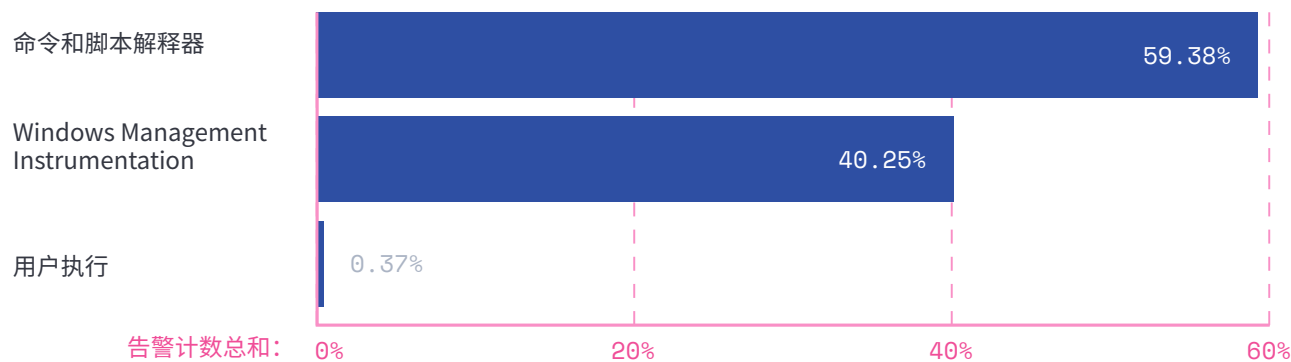


图 10: 执行技术

关于执行, Elastic Security Labs 发现约 59% 的执行技术与命令和本地脚本解释器有关, 剩下的 40% 完全是因为滥用 Windows Management Instrumentation (WMI) 所致。Windows 终端尤其如此, 原因在于攻击者会使用 PowerShell、Windows 脚本宿主和 Windows 快捷方式文件来执行命令、脚本或二进制文件。

如下图所示, 我们再次看到 RunDLL32 这个 Windows 本地二进制文件在入侵的后期阶段被攻击者滥用。此外, Elastic 安全还经常观察到 Windows 脚本宿主 (wscript.exe 或 cscript.exe) 被用来在 Visual Basic Script (VBS) 和 JavaScript (JS) 文件中运行恶意代码。

规则名称	告警计数总和
通过 RunDLL32 启动命令 shell 活动	27.53%
使用异常文件扩展名执行 Windows 脚本	25.95%
可疑的 Windows 脚本解释器子进程	13.51%
从异常目录执行	11.56%
可疑的 Windows 脚本进程	9.07%
通过 Windows 脚本执行可疑的 PowerShell	4.21%
异常 PowerShell Engine ImageLoad	2.88%
执行 Windows 脚本主机写入的文件	1.91%
从存档文件执行 Windows 脚本	0.63%
执行通过 LOLBIN 下载的 Windows 脚本	0.60%

表 3: 触发的 Elastic 执行规则

凭据访问

随着本地托管和云服务提供商 (CSP) 之间的混合部署环境的持续趋势, 攻击者会继续依赖有效帐户, 因为这些帐户不太会引起管理员的怀疑。如果叠加离地攻击 (LotL) 技术, 防御程序可能难以区分预期和潜在的恶意活动。因此, 凭据访问不仅是一个常见的终端战术, 在 CSP 环境中也是如此, 详细介绍请见“云安全趋势”小节中的“全球发现”部分。

在所有凭据访问技术中, 大约有 77% 是使用大家熟悉的实用程序 (也称为“转储工具”) 进行操作系统凭据转储, 因为它们可让攻击者以哈希值或明文形式从操作系统转储凭据。

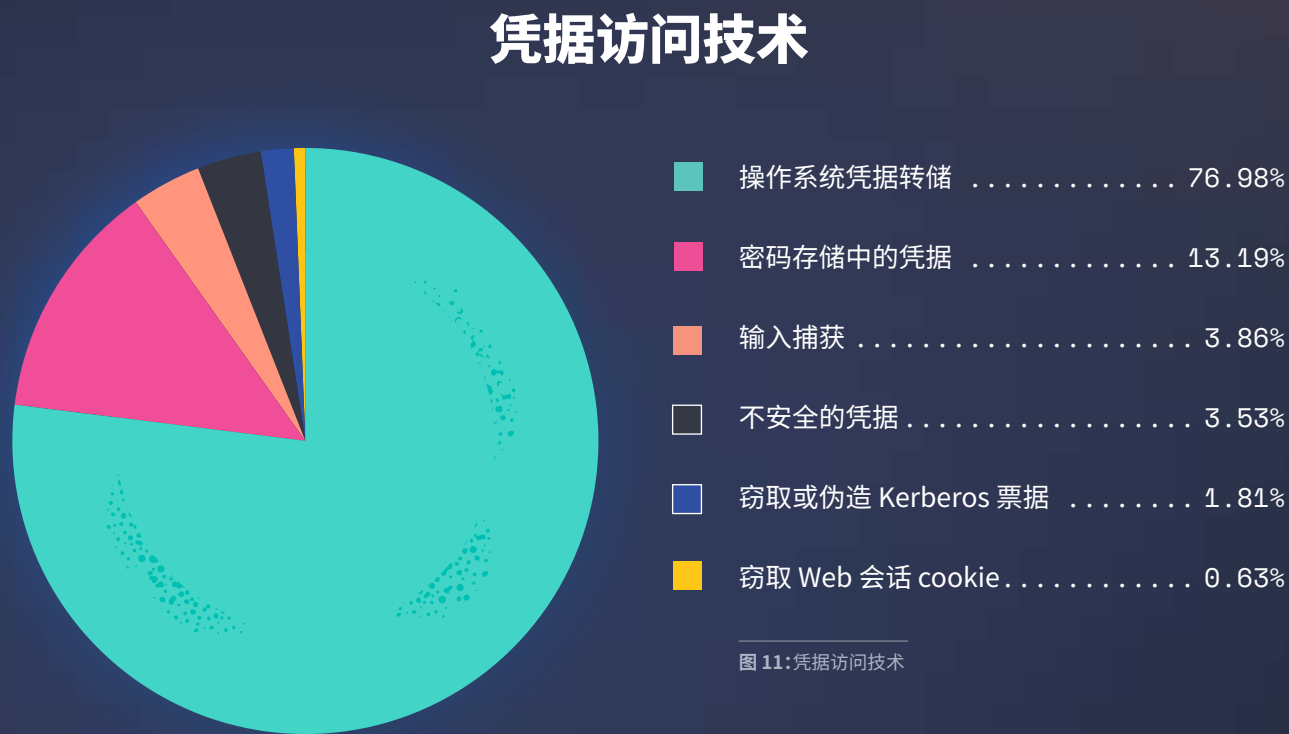


图 11: 凭据访问技术

按所用工具划分的凭据访问

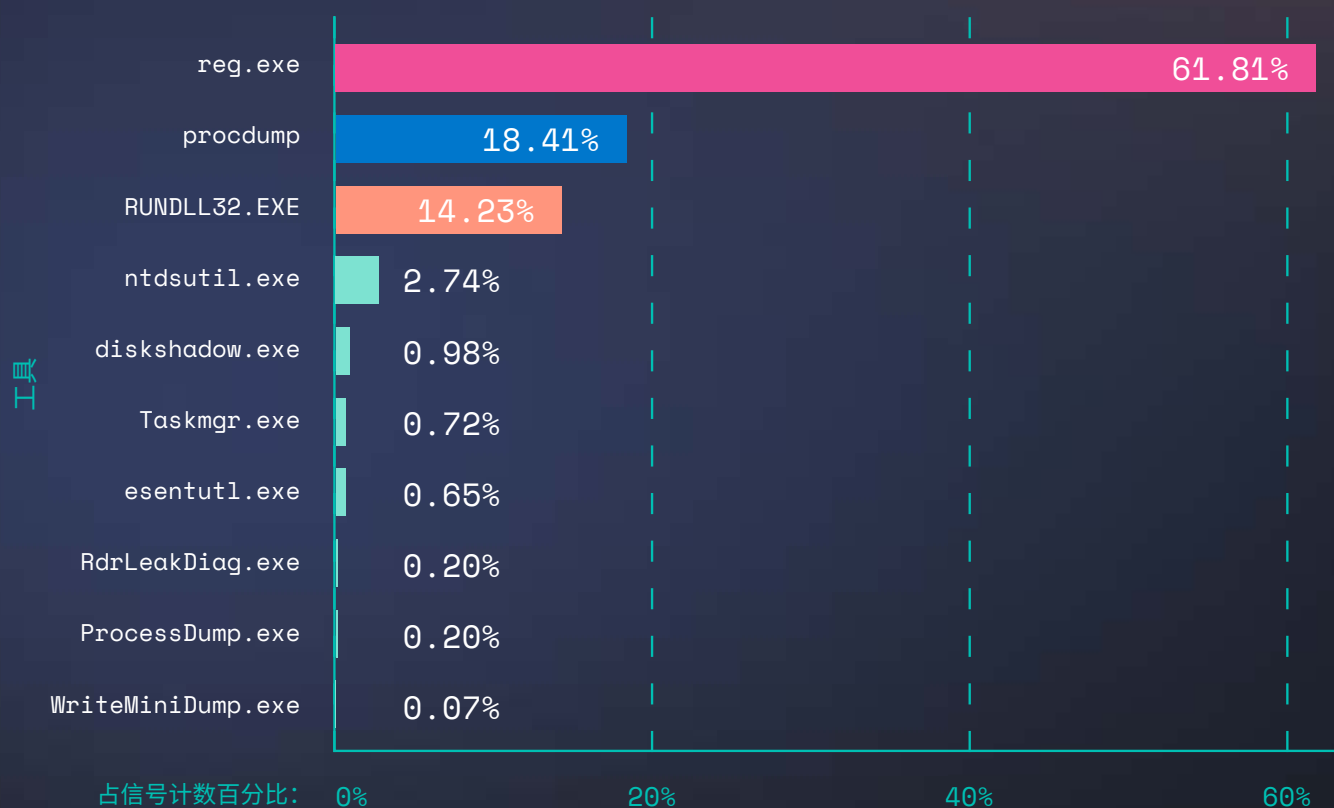
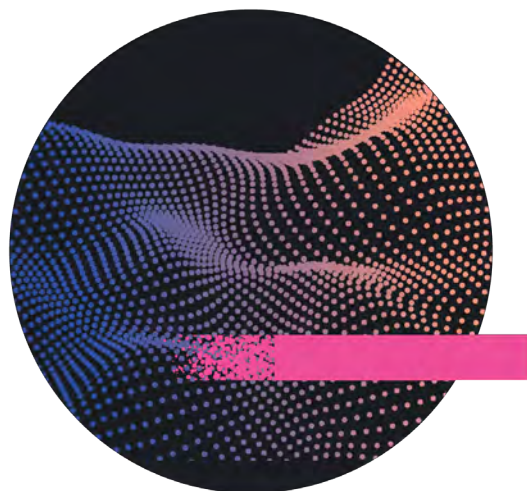


图 12: 按所用工具划分的凭据访问

如下表所示, reg、procdump 和 RunDLL32 在我们的数据中占据很大的比重,这在很大程度上是因为它们都是无害的实用程序,因此 Elastic 的反恶意软件功能在通常情况下并不会横加干预。得益于针对恶意软件防护的分层措施,像 Mimikatz 这样的常用工具通常出现的次数较少。对于 Windows 终端中的注册表,可以使用 reg save 和 reg export 命令,通过安全帐户管理器 (HKLM\SAM) 或 LSASS 策略数据库 (HKLM\SECURITY) 配置单元直接与注册表交互。

下表列出了来自 Elastic 安全遥测的凭据访问信号,其中包含有关检测到的内容的其他详细信息。



通过已知实用程序进行凭据访问	33.37%
安全帐户管理器 (SAM) 注册表访问	17.96%
对 LSA Secrets 注册表进行可疑访问	11.18%
通过 Mimikatz 进行潜在的凭据访问	10.72%
对 Windows 凭据管理器存储区进行潜在发现	3.99%
通过 OSAScript 进行潜在的凭据网络钓鱼	3.86%
对 DPAPI 主密钥进行潜在发现	3.57%
敏感文件访问 — SSH 保存的密钥	3.16%
安全帐户管理器 (SAM) 文件访问	2.92%
通过异常进程访问 Web 浏览器凭据	2.14%

表 4: 规则名称和告警总数



持久化

涉及 Registry Run/RunOnce 子键和排定任务的常见持久化机制是最常被观察到的。尽管这个趋势不足为奇,但它表示这些技术会在相当长的一段时间内被经常使用,如今它的有效性依然保持 2012 年的水平。

这些持久化机制以用例一向无害的操作系统基本功能为基础,这也是攻击者依赖它们的原因之一。这一信息也可在下图中找到佐证,其中我们看到约 87% 的持久化技术都是启动或登录自动启动执行。

持久化技术

87.31%

启动或登录自动启动执行

告警计数总和

11.12%

排定的任务/作业

0.81%

创建或修改系统进程

0.47%

浏览器扩展

0.29%

BITS Jobs

图 13:持久化技术

Elastic Security Labs 发现, 这些信号中的大多数都与创建或修改注册表运行键或 Windows 终端启动文件夹中的文件有关。那些不是由本地系统帐户执行的操作 (预期的进程通常包括 PowerShell、Windows Update Agent、Windows Installer 和其他一些进程等), 将表明异常活动值得进行调查。

我们发现的一个特别常见的操作是, 通过 Windows 服务主机 (svchost) 在用户的 StartUp 文件夹中创建 Windows Shortcut (LNK) 文件, 该文件通常直接指向本机二进制文件, 如 cmd.exe 或 powershell.exe, 可执行先前安装的有效负载或脚本。这通常会作为一种持久化机制来完成, 以确保即使重新启动终端也能运行恶意代码。Elastic Security Labs 在 [BLISTER](#) 的发现结果和分析中也注意到了这一相同的技术。

Elastic Security Labs 发现, 今年早期发布的 Exchange 漏洞与 webshell (威胁可按需调用的基于 Web 的恶意软件) 的存在之间有着明显的关联性, 但在统计学上并不显著, 这在很大程度上是因为本地部署的 Exchange 服务器未打补丁所导致的。

云安全趋势

Elastic 安全使用的是来自全球各地客户的遥测数据, 这些客户均利用预先打包的检测规则来分析基于云的威胁和潜在的攻击。这些遥测数据让 Elastic Security Labs 能够深入了解客户每天在 Microsoft Azure、Amazon Web Services (AWS) 和 Google Cloud 中看到的潜在威胁。

在以下分析中, Elastic Security Labs 重点介绍了来自客户以及在 2022 年 4 月至 8 月期间收到的基于云的事件。

全球发现

Elastic Security Labs 分析了来自客户集群的遥测数据, 这些集群在 Microsoft Azure、AWS 和 Google Cloud 中都利用了我们的 SIEM 预购建检测规则, 而这只是共享遥测数据的客户中的一小部分。这些事件中约有 57% 与 AWS 直接相关, 其次是 Google Cloud (~22%) 和 Microsoft Azure (~21%)。与包括终端在内的整体威胁检测告警相比, 基于云的检测结果占全球所有 SIEM 检测告警的 5% 左右。

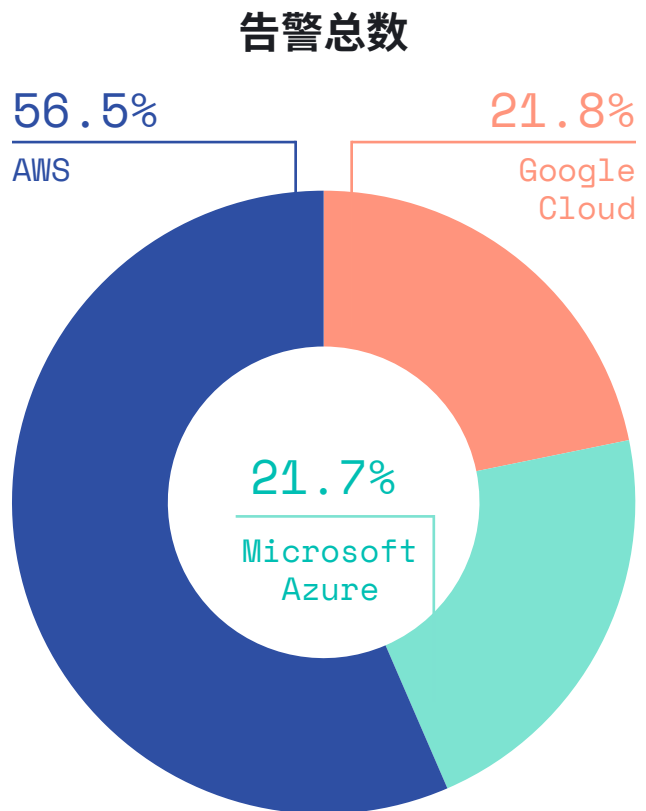


图 14: 占 CSP 基于云的检测告警总数的百分比

与 AWS 检测结果相关的事件占我们收到的所有基于云的事件的一半以上。根据 [Statista](#) 的数据, AWS 在云基础架构服务提供商中占有 34% 的市场份额, 尽管我们的客户可能更喜欢 AWS, 但这可能会影响我们的可见性。在 AWS 和 Microsoft Azure 公开的产品组合中, 共有 200 多种服务, Google Cloud 也有 100 多种可用的服务, 这表明这些 CSP 的攻击面相当大。

Elastic 安全专注于提供战术和技术, 预构建的检测规则与 MITRE 的 ATT&CK 矩阵[相匹配](#), 适用于各个 CSP。在所有 CSP 中, 近 33% 的云告警与[凭据访问](#)有关, Elastic 注意到这经常与[初始访问](#)出现重合。

随着公司逐渐接受 CSP 提供的服务和功能, 传统的本地部署环境正在慢慢过渡到混合模式, 在某些情况下甚至会完全采用云部署。这不仅增加了管理身份和访问管理 (IAM) 用户的需求, 也增加了管理基于服务访问这些资源和应用程序的帐户的需求。如果环境不安全 (例如, 允许使用弱密码、角色权限过多、API 密钥和访问令牌以明文形式存储或缓存在虚拟机上), 那么无论采用什么部署方式, 与这些环境相关的风险都会显著增加。

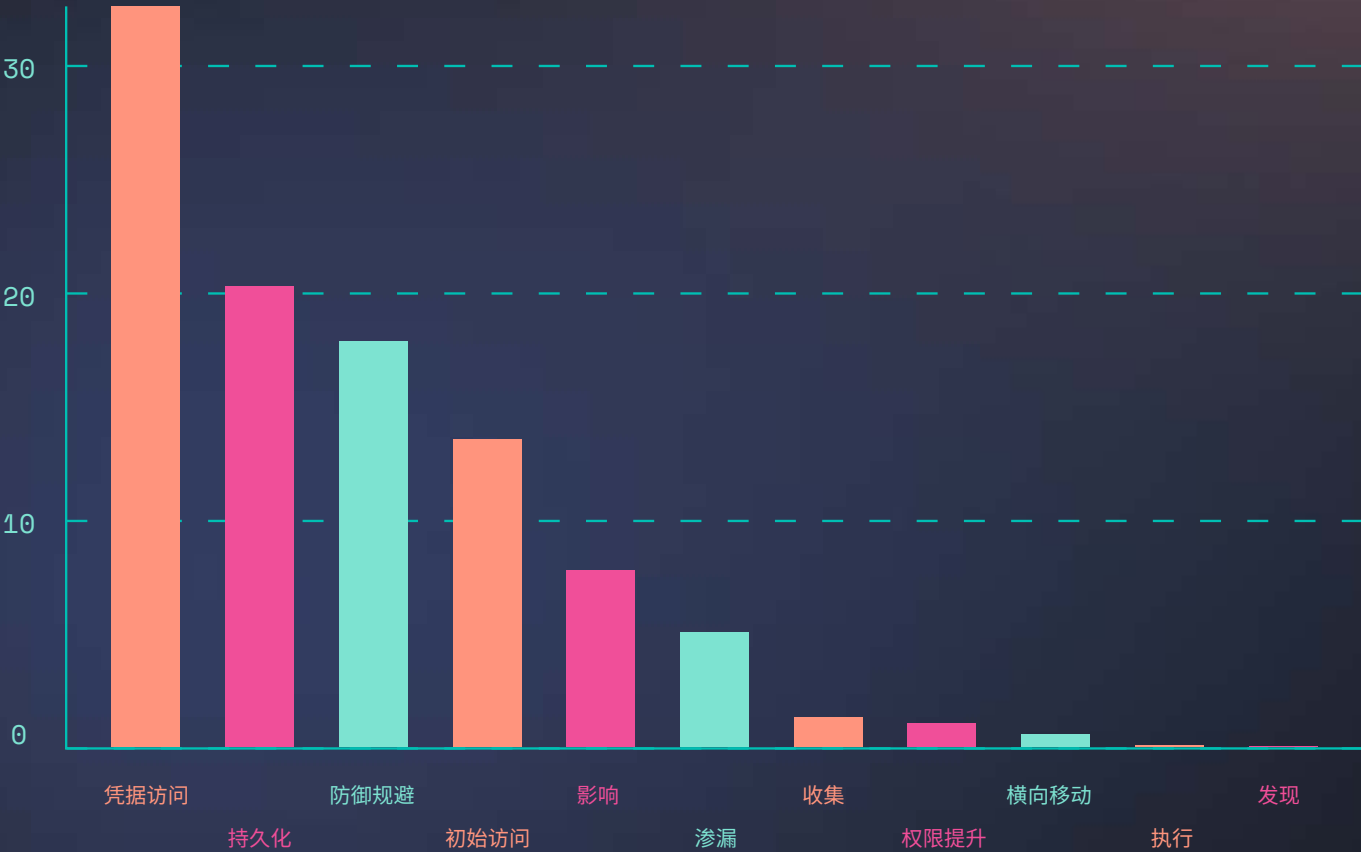


图 15: 基于云的检测告警中占 MITRE ATT&CK 战术名称总数的百分比

Elastic Security Labs 发现, 大约 58% 的初始访问尝试采用的都是传统的强力尝试加之前已经泄露的密码喷洒。41% 左右的凭据访问告警都与试图窃取应用程序访问令牌(相对于其他凭据材料)有关, 其中约有 1% 的尝试依赖的是默认的不安全凭据。虽然 1% 看起来微不足道, 但我们观察到, 受到这些尝试影响的是 Google Cloud 和 Microsoft Azure, 而不是 AWS, 这可能是 AWS 倾向于与我们合作所产生的结果。

如果有效帐户遭到泄露, 并且角色或权限的范围并未明确界定, 那么盗窃凭据通常会带来很大的风险, 因为这些服务允许攻击者从工作区横向移动到 CSP 的管理控制台。

众多 CSP 竞相向客户提供类似的服务, 这么做的后果是威胁攻击面可能存在相似之处, 但 Elastic Security Labs 仍决定大致查看一下每个 CSP 的检测规则, 试图发现任何应该引起读者注意的特定威胁趋势。

AWS 发现

如前所述, AWS 占据了当前 CSP 市场近 34% 的份额, 产品服务种类繁多。在分析过程中, Elastic Security Labs 发现, 凭据访问、初始访问和持久化占有所有检测告警量的 74%。我们认为权限提升的占比可能会更大, 但它只占告警量的不到 2%。

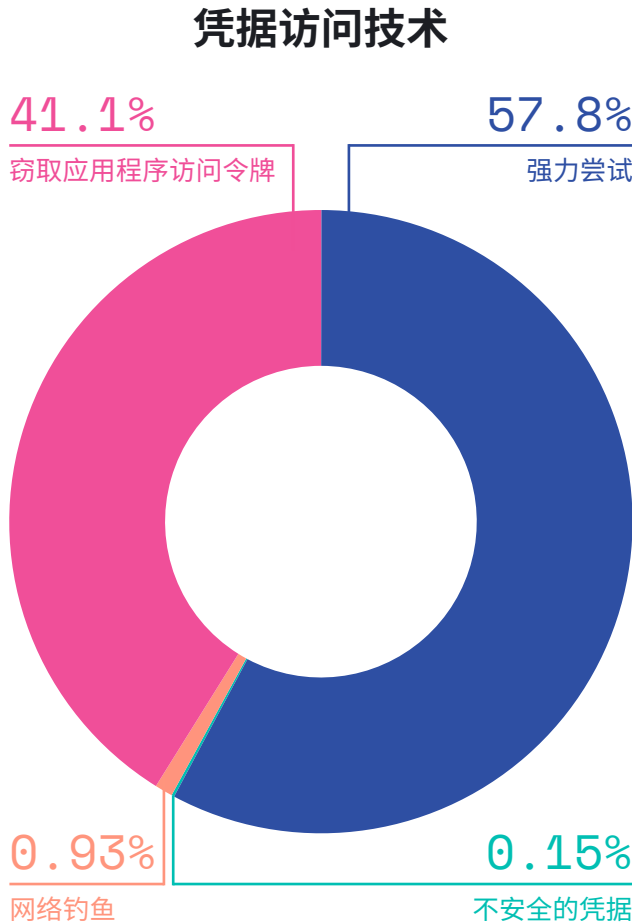
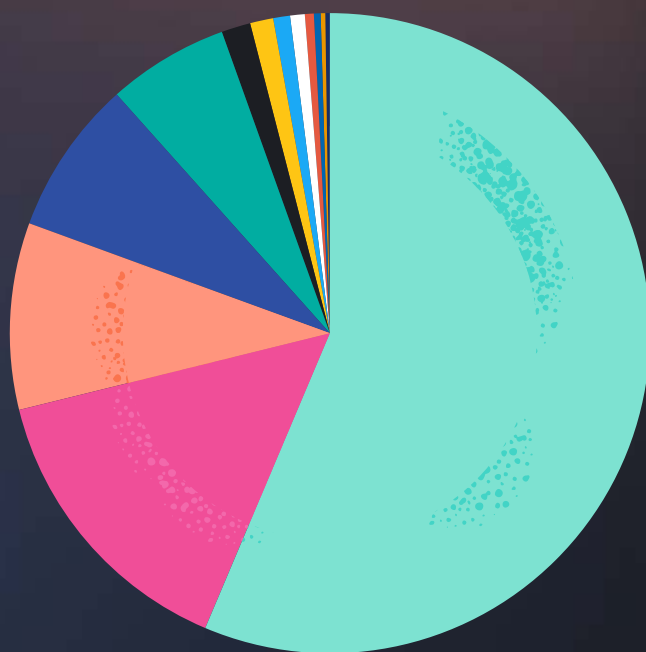


图 16: 占 MITRE ATT&CK 中有关凭据访问战术技巧的百分比

AWS 技术



图 17:ATT&CK 技术在 AWS 技术中所占百分比



如上图所示,在 AWS 中观察到的所有技术中,约 57% 与试图窃取应用程序访问令牌有关。这通常涉及通过调用 GetSessionToken API 从 AWS 的 Security Token Service (STS) 检索临时凭据。在执行方面,Elastic Security Labs 观察到存在滥用 AWS CLI 以使用系统管理器资源的现象,其目的是在 EC2 中的托管实例上调用预购建的文档。这尤其有利于进行发现和枚举,有时还可以更加先进,借助为执行 PowerShell 而在本地创建的文档,以 Windows 主机为攻击目标。

虽然这看起来无关紧要,而且产生的信号真正无害,但 Elastic Security Labs 依然为每个 CSP 创建了检测逻辑,并删除了日志记录功能、存储或文件。通常情况下,CSP 的环境都是设置为将日志记录采集到单个管道或存储资源中,一经删除即会变成一个单点故障,因为攻击者的任何入侵痕迹都将不复存在,这给事故响应 (IR) 参与造成了困难。近 9% 的 AWS 信号涉及日志流、分组和告警删除。

我们发现,57% 的 AWS 告警来自 Elastic Compute Cloud (EC2) 环境。当 EC2 环境配置不当并允许使用默认凭据进行远程访问时,最常见的攻击者策略是识别 IAM 用户的身份、发现令牌和访问密钥。EC2 实例元数据经常会包含半敏感的信息。在这些情况下,即使是低成熟度的威胁也很容易实现。EC2 CloudTrail 生成的告警中约有 39% 主要针对 IAM 用户帐户,这意味着这些环境中的密钥可能面临更大的风险。

Microsoft Azure 发现

随着业务从本地部署模式过渡到混合或完全基于云的环境, Microsoft Azure 可能比 AWS 或 Google Cloud 的风险更大。Active Directory (AD) 和 SharePoint 等关键且经常成为目标的资源都托管在 Microsoft Azure 中。Elastic 安全发现, 从 Microsoft Azure 观察到的告警中, 有 96% 与身份验证事件有关。有效帐户最常用于尝试检索 OAuth2 令牌, 进行网络钓鱼攻击和实施其他技术。

Microsoft Azure 也受到了若干种恶意技术共同作用的影响, 其中像创建 Microsoft Azure 自动化运行手册这样的技术后来导致了创建后门, 并且“同意授予攻击”让攻击者能够请求有关有效用户的详细信息。通常情况下, Microsoft Azure 服务主体是初始有效帐户泄露的目标, 因为这些身份是为与应用程序、自动化工具和本地服务搭配使用而创建的, 其中用户能够以本地系统用户的身份在虚拟机上执行代码。

如果攻击者成功窃取了有效帐户并有权访问虚拟机, 则在入侵时一般会利用 Microsoft Azure 的命令行界面 (CLI) 进行其他发现和枚举。使用帐户、资源、密钥库和网络等命令, 攻击者可以查看有关特定授权用户的 Microsoft Azure 敏感订阅信息。与此相关的是, 经常可以看到 `run-command` 在 Microsoft Azure 虚拟机上执行。Microsoft Azure 中的这项功能使用了一个在配置 Microsoft Azure 虚拟机时安装在其上的代理。相关风险来源于随这项功能一起安装的预配置 PowerShell 脚本, 如果遭到滥用, 攻击者就可以轻松修改或深入了解 Microsoft Azure 基础架构, 在虚拟机上执行脚本或访问关键资源 and 应用程序。

Microsoft Azure 技术

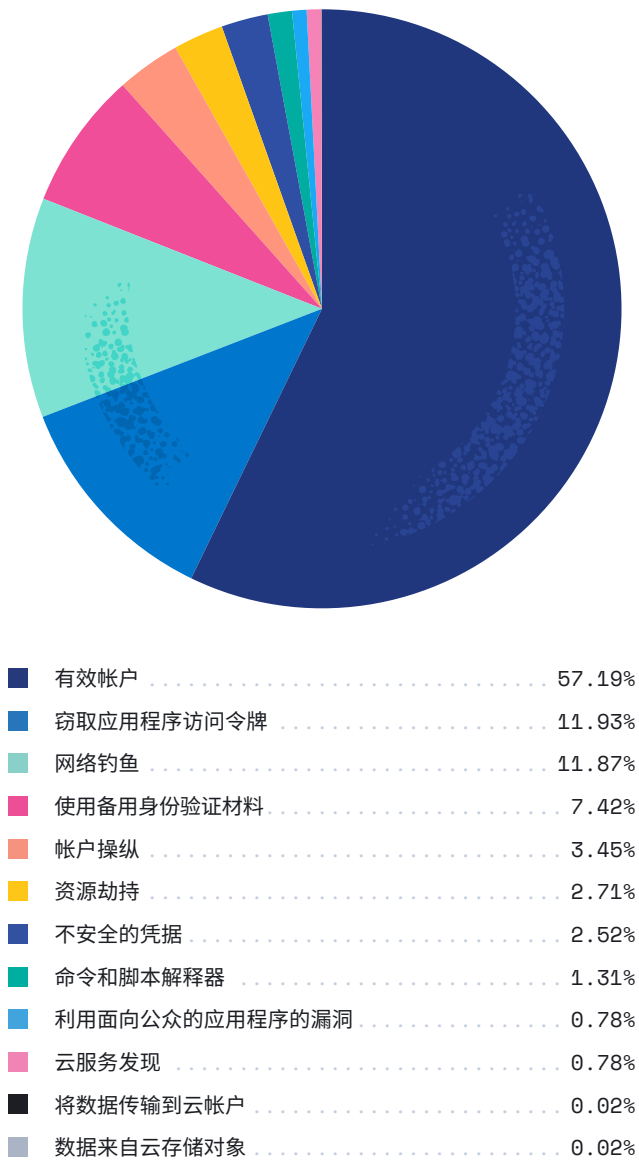


图 18: 在 Microsoft Azure 环境中发现的各种 ATT&CK 技术所占百分比

Microsoft Azure PowerShell 是另一种经常被滥用的本机资源,一旦具有非限制性权限或角色的有效帐户遭到入侵,攻击者就可以利用该资源。有几个预构建的模块不仅可以与帐户所在的虚拟机进行交互,还可以与资源和应用程序,例如 Microsoft Azure SQL、Microsoft Azure Storage Blobs,当然还有 Microsoft Azure Active Directory 进行交互。

Google Cloud 发现

正如 Microsoft Azure 与 Office 365 形成了一个组合攻击面一样,Google Cloud 的攻击面也因 Google Workspace 而有所扩大,其中 Google 云端硬盘和 Gmail 等应用程序对企业都至关重要。尽管本报告并未特别关注 Google Workspace,但 Elastic Security Labs 也积极开发了[公共可用](#)的威胁检测规则。

Google Cloud 为客户和开发者提供了一个简单明了的架构和设置,便于轻松部署可管理的云爆发模式,并可使用用于数据丢失防护 (DLP) 的聊天机器人、移动应用后端支持,以及 Google 计算引擎 (GCE) 中的虚拟终端等等。

不管客户依赖 Google Cloud 的原因是什么,如果不更改默认的帐户凭据,服务帐户的泄露就会依然猖獗。来自 Google Cloud 环境的告警中约有 54% 与服务帐户滥用有关,但目前尚不清楚其中有多少涉及默认凭据。虽然服务帐户密钥生成是一种有效的持久化方法,但如果“iam.serviceAccountTokenCreator”只是简单应用到已经遭到攻击者入侵的有效帐户,那么这通常是多余的。

Google Cloud 技术

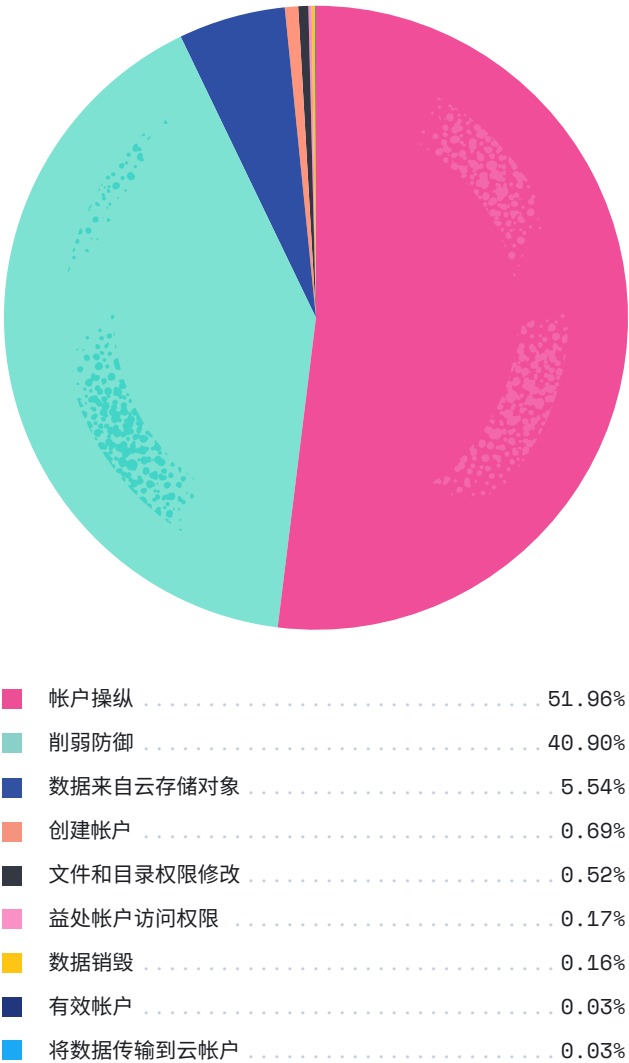


图 19: ATT&CK 技术在 Google Cloud 技术中所占百分比

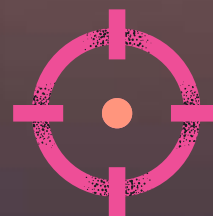
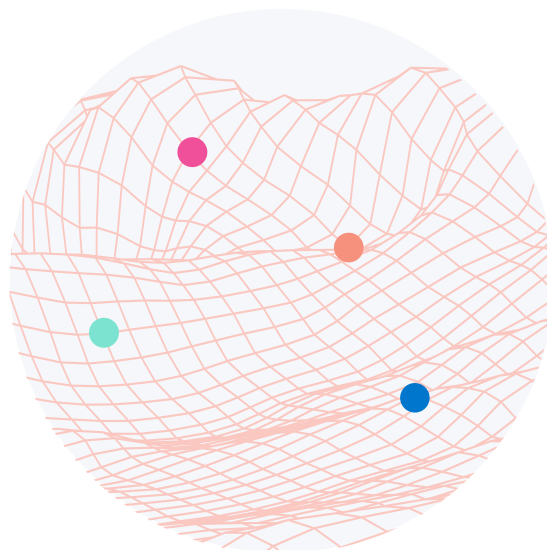
威胁配置文件

这部分总结了 Elastic 在过去一年中制作的威胁配置文件,对此我们有一些独特的遥测见解。Elastic 利用我们的遥测数据来发现和跟踪威胁。

有以下四个主要的活动组:

- **BLISTER** [REF7890]
- **PHOREAL** [REF4322]
- **CUBA** [REF9019]
- **QBOT** [REF3726]

针对所列的每个组,我们都会提供一个称为“钻石模型”的常规图表,用来说明攻击者、基础架构、功能和受害者之间的关系。为方便阅读,我们删去了与其他供应商所跟踪群组的重合部分,但读者应该注意到,这并不代表我们与这些供应商意见一致或有分歧。



钻石模型

我们会利用钻石模型来描述攻击者、功能、基础架构和入侵受害者之间的大致关系。这个模型通常会以入侵为中心的方式使用,但在这里,我们将以攻击者为中心的方式使用它,以便展示我们对许多事件的观察结果。

术语

活动群组:被认为行动带有不良意图的个人、群组或组织。我们会在这些活动群组前面加上字符串 REF 和一组数字,用来区分我们和其他竞争对手。

攻击模式:描述攻击者试图攻击目标的方式。

入侵基础设施:被认为由单个组织编排的对抗行为和具有公共属性的资源。

Blister [REF7890]

2021 年 12 月 22 日, Elastic [发现](#)了一种新型的恶意软件加载程序, 我们称之为 BLISTER。执行过程中, BLISTER 加载程序会从自身内部解密后门, 并在内存中执行该后门, 从而影响单个客户环境。这个活动群组与一些第三方标签重叠。

图 20 显示的是初始加载程序中存在的代码签名元数据, 其中可以看到, 二进制文件在 Elastic 发现它之前的近两个月就已经准备好了。数字签名处将“Blist LLC”列为签名实体, 也就是这个加载程序家族的名称。读者应该知道, 受“BLISTER”影响的有效负载可以由几个低成本证书颁发机构中的任何一个进行签名, 而其中没有一个可以合法地对后门二进制文件进行签名。

通过利用 BLISTER, 一个无害的应用程序具有了确保大多数二进制文件的代码也是无害的作用。这种方法可能会骗过未将无害软件纳入训练数据中的机器学习功能, 并且使用有效的代码签名通常也能在人类分析人员面前蒙混过关。这种深入攻击的方法可以有效地绕过企业的各种缓解措施。

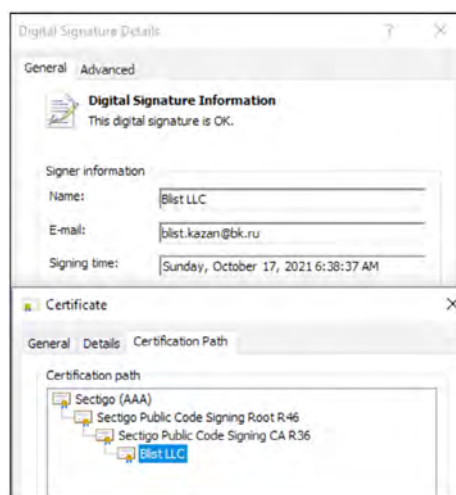


图 20: BLISTER 加载程序代码签名元数据

有何威胁?

BLISTER 是一种隐蔽的恶意软件加载程序, 用于通过各种技术执行有效负载。由于几乎任何无害应用程序都可以修改为类似 BLISTER 的加载程序, 因此, 这个方法的一个特点是受 BLISTER 影响的加载程序继承了代码签名元数据, 通常可绕过脆弱的安全控制。

有何影响?

REF7890 使用 BLISTER 来加载包括攻击性安全工具 (OST) Cobalt Strike 和 BitRat 后门在内的植入程序。这为受感染主机提供了多种远程访问功能。在 Elastic 的所有观察结果中, BLISTER 都被用来协助数据盗窃和勒索。

Elastic 有哪些应对措施?

Elastic 针对 BLISTER 加载程序提供了开箱即用型的检测和防御功能。此外, Elastic 还公开发布了 YARA 规则、猎捕查询、详细的活动和恶意软件分析, 以及一个配置提取器。

了解详情

- [BLISTER 加载程序](#)
- [BLISTER 恶意软件活动](#)
- [BLISTER 配置提取器](#)

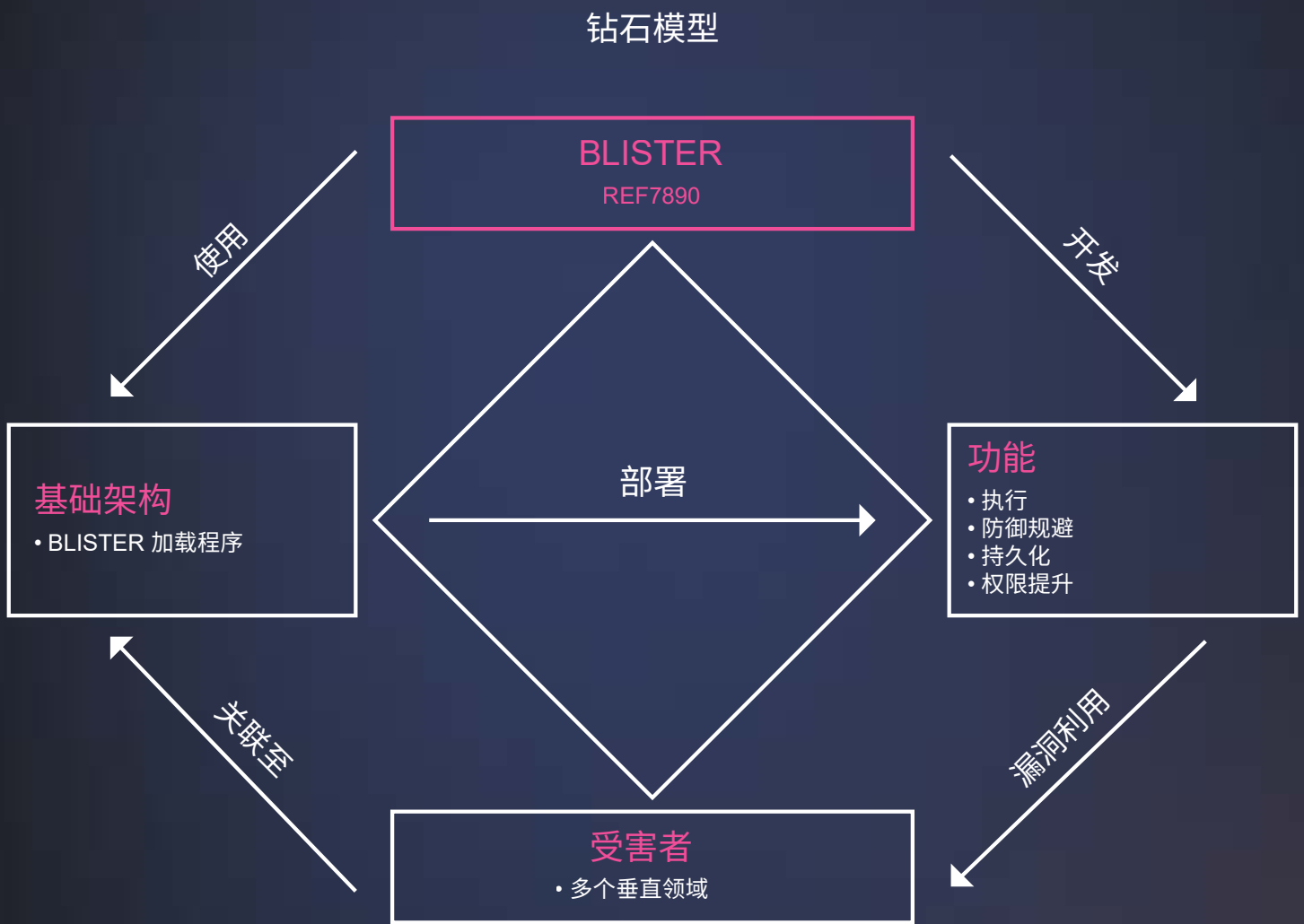


图 21: BLISTER 钻石模型

Phoreal [REF4322]

今年早些时候, Elastic [发现](#)了影响越南金融机构的 PHOREAL 后门(通常被称为 RIZZO 后门)的存在。这次感染之所以引人注意, 是因为使用了在内存中规避的方法, 而这种做法此前未曾在植入程序中见过。这些特殊告警很值得关注, 因为它们都发生在同一个集群中, 而且反常的是, 它们针对的是 control.exe 进程。Windows control.exe 进程负责处理控制面板项的执行, 借助这些实用程序, 用户能够查看和调整计算机设置。Elastic 注意到存在与 APT32 和 OCEANLOTUS 第三方标签重叠的部分。

有何威胁?

PHOREAL 是一个功能齐全的后门, 允许通过初始访问和漏洞利用后操作来获取受害者的数据。PHOREAL 操作者至少从 2014 年就开始活跃了, 方法和功能也随着时间的推移不断发展。

有何影响?

REF4322 主要针对东南亚 (特别是越南) 地区在私营和公共领域均有涉足的受害者。Elastic 以中等信心认定这种威胁是以国家为目标的, 而受害者研究结果表明经济、政治和工业间谍活动才是目标。

Elastic 有哪些应对措施?

Elastic 安全团队详细介绍了如何对其中一个威胁告警进行分流, 提取终端和网络过滤的可观察结果, 并生成新的恶意软件签名, 用于在已部署的 Elastic Agent 队列中识别和缓解威胁。

了解详情

- [PHOREAL 恶意软件专门攻击东南亚金融部门](#)

钻石模型



图 22:PHOREAL 钻石模型

CUBA [REF9019]

今年 6 月, Elastic 观察到出现多次与 CUBA Ransomware Group 相关的入侵尝试, 这些尝试均基于常用的 CUBA 勒索软件有效负载和共享基础架构。虽然各个行业都有用户受到了影响, 但 Elastic 无法确定进行初始访问的通用方法。有些组织的入侵途径是未打补丁的漏洞, 而其余的似乎是经由自身环境中未得到有效修复的毫不相干的恶意软件被入侵的。Elastic 注意到与 UNC2596 第三方标签重叠。

与 REF9019 相关的活动模式涉及各种恶意软件植入程序, 如 COBALTSTRIKE、METASPLOIT、BUGHATCH 和 SYSTEMBC, 以及有效的远程支持实用程序, 如 GoToAssist。

以下汇总了在部分单一受害者环境中观察到的技术:

- 利用面向公众的应用程序的漏洞
- 命令和脚本解释器 — PowerShell 和 Windows Command Shell
- 排定的任务/作业 — 排定的任务
- 启动或登录自动启动执行 — 注册表运行键/启动文件夹
- 创建帐户 — 本地帐户
- 操作系统凭据转储 — LSA Secrets
- 数据加密影响
- 隐藏工件 — 隐藏窗口
- 伪装 — 匹配合法名称或位置
- 混淆文件或信息
- 反射式代码加载

有何威胁?

这个活动群组利用 CUBA 勒索软件和各种远程访问功能来攻击北美和欧洲地区的零售商和制造商。威胁群组遵循了一套有效但重复的战术、技术和程序 (TTP), 用于进行初始访问、横向移动、渗漏、勒索软件部署和勒索。

有何影响?

REF9019 针对的是北美和欧洲地区的零售商和制造商, 通过加密和窃取敏感文件进行敲诈勒索。

Elastic 有哪些应对措施?

Elastic 已公开发布 YARA 签名、猎捕查询和终端保护措施, 以此来检测这个勒索软件家族。

了解详情

- [CUBA 勒索软件活动分析](#)
- [CUBA 勒索软件恶意软件分析](#)

钻石模型

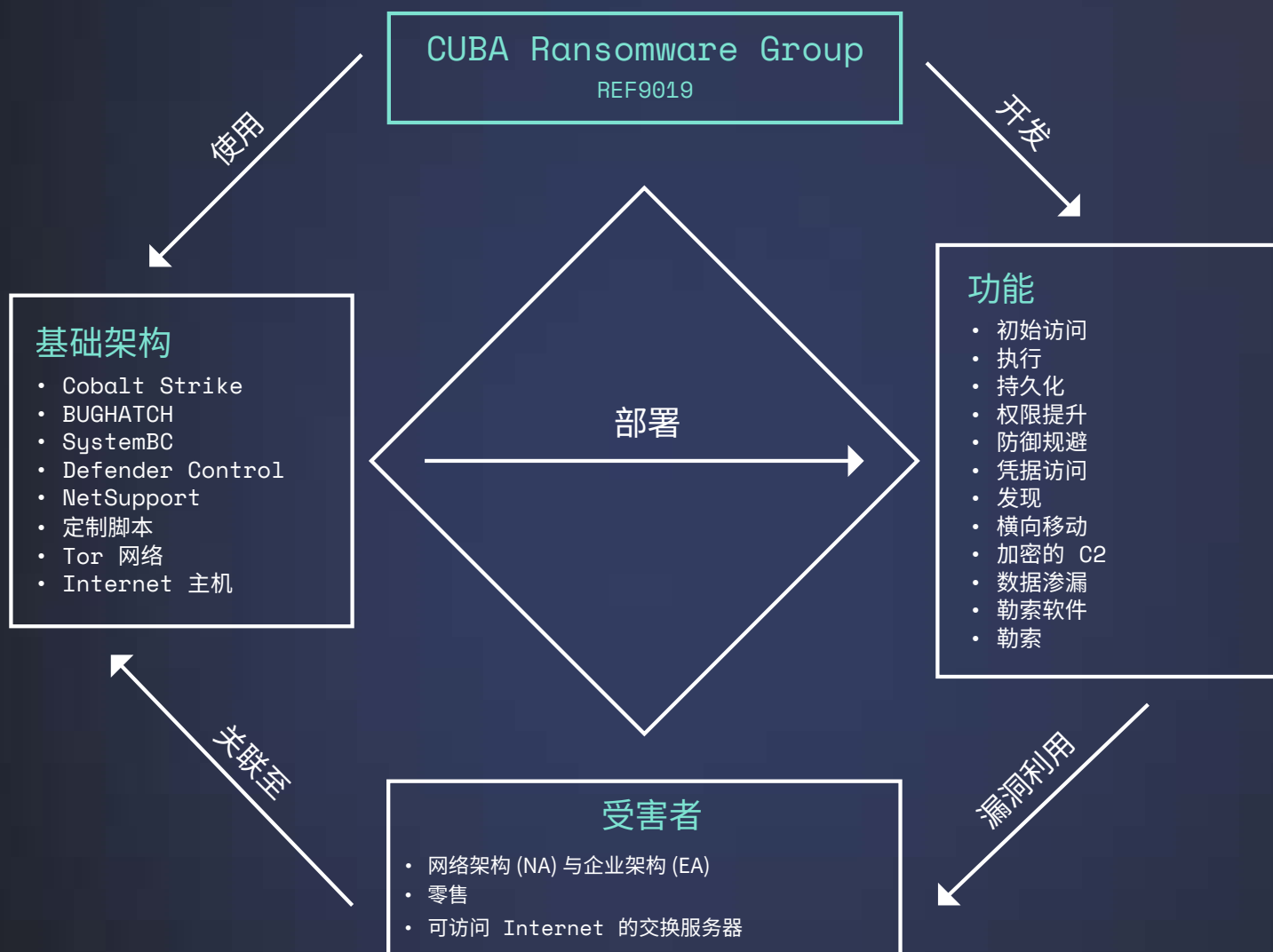


图 23: CUBA 钻石模型

QBOT [REF3726]

QBOT (也称为 QAKBOT) 是目前全球仍在使用的最庞大的恶意软件家族之一, 大约从 2007 年开始不断开发。这个恶意软件被用来为涉及勒索软件的犯罪行为提供便利, 因其使用多阶段执行的方法以及采用例外清单来避免感染东欧国家的系统而为人所知。Elastic 将这种活动模式命名为 REF3726 并进行跟踪, 同时指出其在广泛可用的购买功能方面与大量供应商标签重叠。

为实现初始访问, 这个恶意软件的现代版本依靠的是 regsvr32.exe 执行代理等本机功能。这可以通过各种初始访问机制来实现, 例如利用客户端软件的漏洞、经过武器化改造的文档诱饵、后门合法软件和软件供应链泄露。图 24 展示了一种常见的初始执行方法。

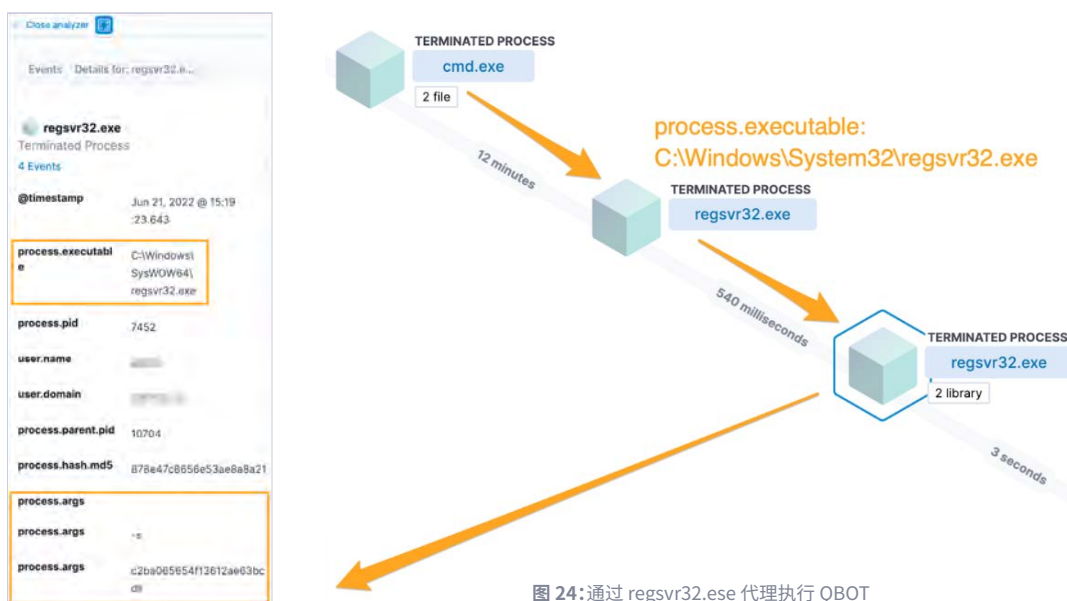


图 24: 通过 regsvr32.exe 代理执行 QBOT

有何威胁?

QBOT 这一不断繁殖的模块化木马, 大约从 2007 年开始活跃至今, 是一种受经济利益驱动的威胁的支持机制。

有何影响?

REF9019 针对的是北美和欧洲地区的零售商和制造商, 通过加密和窃取敏感文件进行敲诈勒索。

Elastic 有哪些应对措施?

Elastic 已公开发布终端保护措施、预构建的检测引擎逻辑、YARA 规则和配置提取器。此外, Elastic 还利用对 QBOT 的研究将 138 个攻击者拥有或控制的 IP 地址与 339 个恶意文件关联起来。

了解详情

- [探索 QBOT 攻击模式](#)
- [QBOT 恶意软件分析](#)
- [QBOT 配置提取器](#)

钻石模型

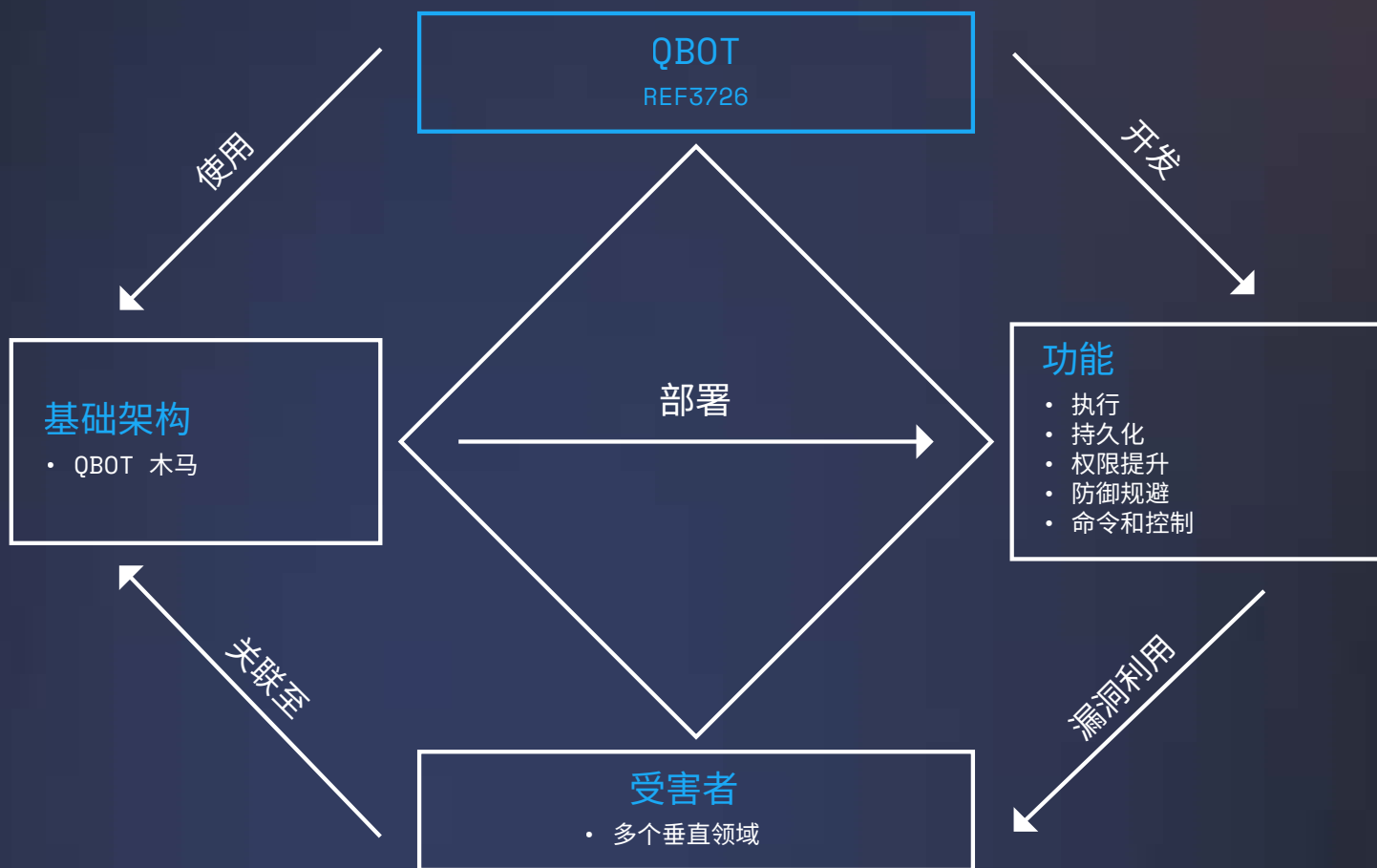


图 25: QBOT 钻石模型

预测与建议

根据趋势、关联性和对不断变化的全球威胁形势的持续研究, Elastic 提出了以下预测和建议。读者应该注意到, 下面这些预测并不是一种预言, 而仅表示可能产生的结果, 这些结果受到太多因素的影响, 无法给出准确猜测。此外, 读者还应该将建议视为提议, 而不是防御网络威胁的保证。

预测 1:

攻击者将继续滥用内置的二进制代理来绕开安全检测工具。

各种威胁仍然会利用 Rundll32.exe 等本机工具作为二进制代理, 通过仔细模仿这些工具的预期用途来加载恶意软件。由于确实行得通, 因此这些工具将仍然受到欢迎, 预计还将长期保持有效性。

建议 1

企业应密切监测系统二进制代理软件的使用, 并建立有关无害和恶意活动模式的知识体系。这些工具无处不在, 在初始访问时发挥着重要作用。限制这些工具的使用对预防泄露有立竿见影的效果。

预测 2:

LNK 和 ISO 有效负载将取代更传统的脚本和文档有效负载。

由于 Microsoft 今年决定提升 Windows 系统安全性, 因此 LNK 和 ISO 有效负载类型已经成为应对各种威胁的必要可行方法。很少有组织会仔细检查这些对象类型, 因而导致泄露事件更加频繁地发生。

建议 2

除了少数例外情况, 组织应将 LNK 和 ISO 附件视为存在风险。这些对象的使用可以通过政策加以控制, 并让检测工程师制定检测使用情况的策略。

预测 3:

有效的 IAM 帐户将依然是攻击者的目标。

作为入侵其他目标的手段,窃取凭据是许多攻击者在攻击早期阶段中的必要操作。在这一年里,Elastic 观察到有几个威胁群组窃取了有效凭据,并将其用于验证云资源以及绕过利用漏洞的需要。

建议 3

了解不同类型帐户和个人的正常活动模式以确定这些帐户何时被滥用,这一点至关重要。对于会影响使用有效帐户访问的云托管应用程序或服务的恶意活动模式,可能需要在 CSP、编排者和工作人员级别实现云资源的可见性才可进行识别。同样,还应监测对元数据 API 的访问或 DevOps 中使用的凭据,以便发现非正常帐户行为的异常资源访问。

预测 4:

由主要 CSP (Google、Amazon 和 Microsoft) 托管的服务帐户,如果未配置最低特权权限或配置错误,则会成为攻击者的目标。

服务帐户凭据通常是从初始访问到持久访问的垫脚石,有时可能会意外暴露。提交到公共 GitHub 存储库只是我们看到威胁行为体获取此类凭据的一种方式,随着企业寻求扩大对其基础架构的自动化改造范围,这种做法将越来越有可行性。此外,企业应注意,某些威胁会禁用审计来逃避检测。

建议 4

了解并实施对云资源的安全访问,并为应对攻击者的干扰做好计划。具有多个可见性来源 (CSP 审计、编排者日志、终端传感器检测工具) 的组织在检测和缓解针对云托管平台的攻击方面表现出了更强的能力。

预测 5:

用于后端 DevOps 但部署在云环境中的 Linux 虚拟机成为攻击目标的次数可能会增加，重点是对帐户枚举和凭据访问的威胁。

开发人员依旧是组织一个脆弱的攻击面，不清楚这个风险的企业将会遭到入侵。了解部署到虚拟机的内容的范围以及这些系统本身授予的访问权限，对于确定对组织构成的风险程度至关重要。

建议 5

要知道，攻击者可以轻松快速地从 GitHub 中暴露的密钥转向 CSP 访问权限，并由此获得创建、修改或破坏资源的能力，包括安装恶意软件、窃取数据或故意配置错误。

预测 6:

组织如果过度投资于不支持缓解措施的检测功能，将难以对所有类别的威胁做出安全响应。

简而言之，企业无法使用仅提供安全检测的工具来有效快速地对威胁做出响应。那些无法部署多种功能来集中减轻威胁的企业，在面对快速移动的威胁时就会处于非常不利的地位，无论是针对性的威胁还是其他威胁都是如此。

建议 6

评估自身重建受感染系统、重置已泄露的帐户凭据、将 DNS 条目放入沉洞中、阻止进出 IP 地址的所有流量、隔离主机以及基于备份还原业务关键型数据的能力。确定支持这些结果的检测工具的优先级，并在可能的情况下选择允许自动缓解策略的工具。

结论



全球威胁形势不断变化,新的威胁和能力前赴后继。网络钓鱼诱饵舍弃了恶意宏,转而改用 ISO 或 LNK 对象,这也反映了技术改变那些能力的方式。然而,网络钓鱼攻击仍然是最常用的初始访问方法。这很能说明问题,那就是企业仍未能完全掌控某种风险连续性。

从中我们还可以得知,威胁形势的某些方面无法通过技术轻松解决。相反,成功取决于正确的可见性、能力和专业知识。在几乎所有情况下,我们发现,这三个因素要么共同取得成功,要么共同导致失败。

我们观察到,可见性在企业如何理解自身攻击面方面发挥了重要作用。直到最近,许多组织才将云托管的应用程序或系统视为企业的一部分。也许是由于解决方案所能提供的默认可见性较差,组织几乎没什么理由要依赖这些解决方案作为他们安全检测工具的一部分。

Elastic 主要会将遥测数据用于提升功能的效用,以及通过本报告之类的刊物,为组织提供额外的安全背景信息。我们非常期待有机会以这样的方式与客户合作,分析他们的数据,并在对数据进行匿名化处理后,将我们的研究成果推广到整个安防行业。

我们对全球威胁形势的理解必然会随着形势本身而改变。在数据收集和感官设备上的投入表明,可见性是通向理解的第一步,而理解才能促使我们采取行动。对于那些缺乏可见性的企业来说,采取行动可能不现实,也不可能,由于许多威胁群组已经发展到快节奏的水平,因此采取行动变得越来越重要。

缺乏专业知识的组织可能会面临最大的障碍,也就是,是否依赖供应商和服务提供商来设置、管理和运营自己的安全基础架构。这种依赖性由各种原因引起,通常会使目标实体处于不利地位,无论威胁是新公布的漏洞、决心敲诈的威胁群组,还是地缘政治事件的附带品。

就在今年,Elastic 走出幕后,以一家安全公司的身份出现在大众眼前。凭借自身悠久的开放历史,社区成员得以通过 [Elastic Security Labs](#) 访问我们的研究,借助[保护工件](#)资源,还可以访问我们的大部分安全技术。这些看似无关的努力,实际上都是我们面对不断变化的威胁形势给出应对方法的一部分。可见性、能力和专业知识是我们打算帮助您打造安全环境的方式,以对威胁能够形成强力反制。只要我们在某个位置发现一次威胁,就可以在任何地方一次性进行解决。

我们随时可为您提供所需的服务,并时刻等待您准备好加入我们。

您可以访问我们的 [Elastic Security Labs](#) 页面来了解 [Elastic 安全](#),并针对本报告中提到的威胁(和其他漏洞)做好保护工作。此外,您也可以[在 Twitter 上关注我们](#),了解我们何时发布重要的威胁研究报告。

访问以下链接可查找更多研究：

www.elastic.co/cn/security-labs

在 Twitter 上关注我们：

[@elastic](https://twitter.com/elastic)

